

BURP SUİT TEMELLERİ

[Kaynak](#)

İÇERİK

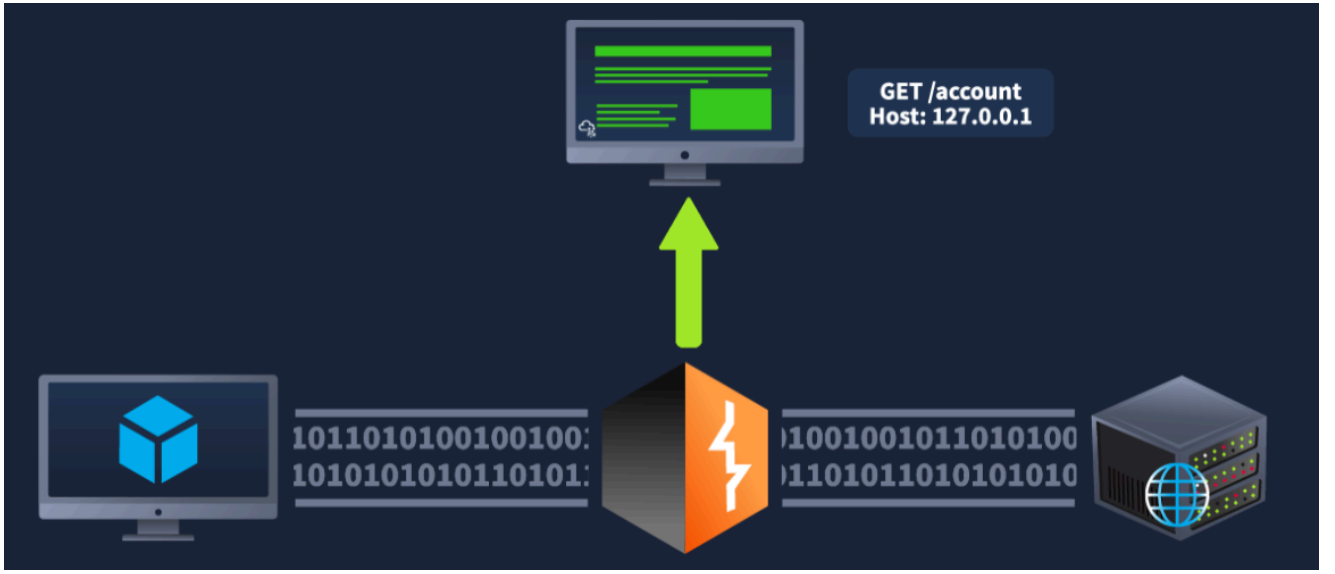
1. Burp Suite Nedir ve Temel Mimari İncelemesi
2. Burp Suite Community Sürümü: Temel Bileşenler ve Teknik İşlevleri
3. Burp Suite Kurulumu ve Çapraz Platform (Cross-Platform) Ortam Yapılandırması
4. Burp Suite Başlatma Süreçleri ve Dashboard (Kontrol Paneli) Analizi
5. Burp Suite Arayüz Navigasyonu ve İleri Düzey İş Akışı Yönetimi
6. Burp Suite Konfigürasyon Mimarisi ve Ayar Yönetimi
7. Burp Proxy Mimarisinin Temelleri ve Trafik Manipülasyonu
8. Burp Proxy ve İstemci Entegrasyonu: FoxyProxy Yapılandırması ve İlk Yakalama (Intercept) Operasyonu
9. Target Sekmesi: Site Map Mimarisi ve Zafiyet Analiz Referansları
10. Burp Suite: The Basics - Task 10 (Site Map Challenge) Çözüm ve Analiz Notları
11. Burp Suite Dahili Tarayıcı (Built-in Browser) ve Sandbox Güvenlik Mimarisi
12. Target Kapsamı (Scoping) ve Operasyonel Trafik İzolasyonu
13. HTTPS Trafiğini Araya Alma (Proxying HTTPS) ve TLS/SSL MITM Mimarisi
14. XSS (Cross-Site Scripting) İstismarı ve Client-Side (İstemci Taraflı) Filtre Atlama (Bypass) Operasyonu

Burp Suite Nedir ve Temel Mimari İncelemesi

Burp Suite, web uygulaması **Penetration Testing** (Sızma Testi - bir sistemdeki güvenlik açıklarını tespit etmek ve istismar etmek amacıyla yapılan yetkilendirilmiş simüle edilmiş siber saldırı) operasyonları için tasarlanmış, **Java** tabanlı kapsamlı bir framework'tür. Günümüzde sadece geleneksel web siteleri için değil, mobil uygulamalar ve arka planda çalışan **API** (Application Programming Interface - farklı yazılımların birbirleriyle veri alışverişi yapmasını sağlayan arayüz) mimarilerinin güvenlik değerlendirmelerinde de tartışmasız endüstri standardı olarak kabul edilmektedir.

Çekirdek İşlev: Proxy ve Trafik Manipülasyonu

Burp Suite'in belkemiğini oluşturan ve onu manuel testler için paha biçilemez kılan en temel yeteneği, bir istemci (web tarayıcısı veya mobil uygulama) ile hedef web sunucusu arasındaki tüm **HTTP/HTTPS** trafiğini yakalayabilmesi ve manipüle edebilmesidir.



Araç, ağ üzerinde bir yerel vekil sunucu (Proxy) olarak konumlanır. Bu sayede trafiği araya girerek (intercepting) durdurur.

Buradaki teknik mantık şudur: İstemciden çıkan bir istek (Request), hedef sunucuya ulaşmadan önce Burp Suite üzerinde bekletilir. Benzer şekilde, sunucudan dönen yanıt (Response), tarayıcıda render edilmeden (görsel olarak işlenmeden) önce yine araya alınabilir.

Bu araya girme işlemi sayesinde analist:

1. Giden paketin içeriğindeki gizli alanları (hidden fields), çerezleri (cookies) veya yetkilendirme (authorization) başlıklarını inceleyebilir.
2. Hedef sunucuyu manipüle etmek için istek üzerinde gerçek zamanlı değişiklikler yapabilir.
3. Yakalanan bu istekleri, Burp Suite framework'ü içerisindeki diğer gelişmiş bileşenlere (Intruder, Repeater vb.) yönlendirerek (routing) daha karmaşık test senaryoları üretebilir.

Aşağıda Burp Suite üzerinden yakalanmış (intercept edilmiş) tipik bir HTTP isteğinin ham (raw) formatı görülmektedir:

```
GET /api/v1/user/profile?id=105 HTTP/1.1
Host: target-app.com
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
Accept: application/json
Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5c...
Connection: close
```

Analiz: Yukarıdaki araya alınmış istekte, normalde tarayıcı arka planında gerçekleşen işlemi net bir şekilde görüyoruz. Saldırgan veya sızma testi uzmanı, bu aşamada `id=105` parametresini `id=1` (potansiyel bir IDOR - Insecure Direct Object Reference zafiyeti denemesi için) olarak değiştirebilir veya `Authorization` token'ını manipüle ederek yetki

yükseltme (Privilege Escalation) denemeleri yapabilir. İsteği değiştirdikten sonra sunucuya iletilmesine izin verir (Forward).

Burp Suite Sürümleri ve Operasyonel Farklılıklar

Kullanım amacına ve yasal gereksinimlere göre Burp Suite üç farklı lisans modeliyle gelir. Pratik uygulamalarımızda yasal sınırlar çerçevesinde ticari olmayan kullanımlar için ücretsiz sunulan **Burp Suite Community Edition** odak noktamız olacaktır. Ancak sektörel hakimiyet için diğer sürümlerin mimari farklarını bilmek şarttır.

1. Burp Suite Professional

Topluluk sürümündeki tüm kısıtlamaların (throttling vb.) kaldırıldığı, siber güvenlik profesyonellerinin sahada aktif olarak kullandığı versiyondur. Aşağıdaki kritik teknik özelliklere sahiptir:

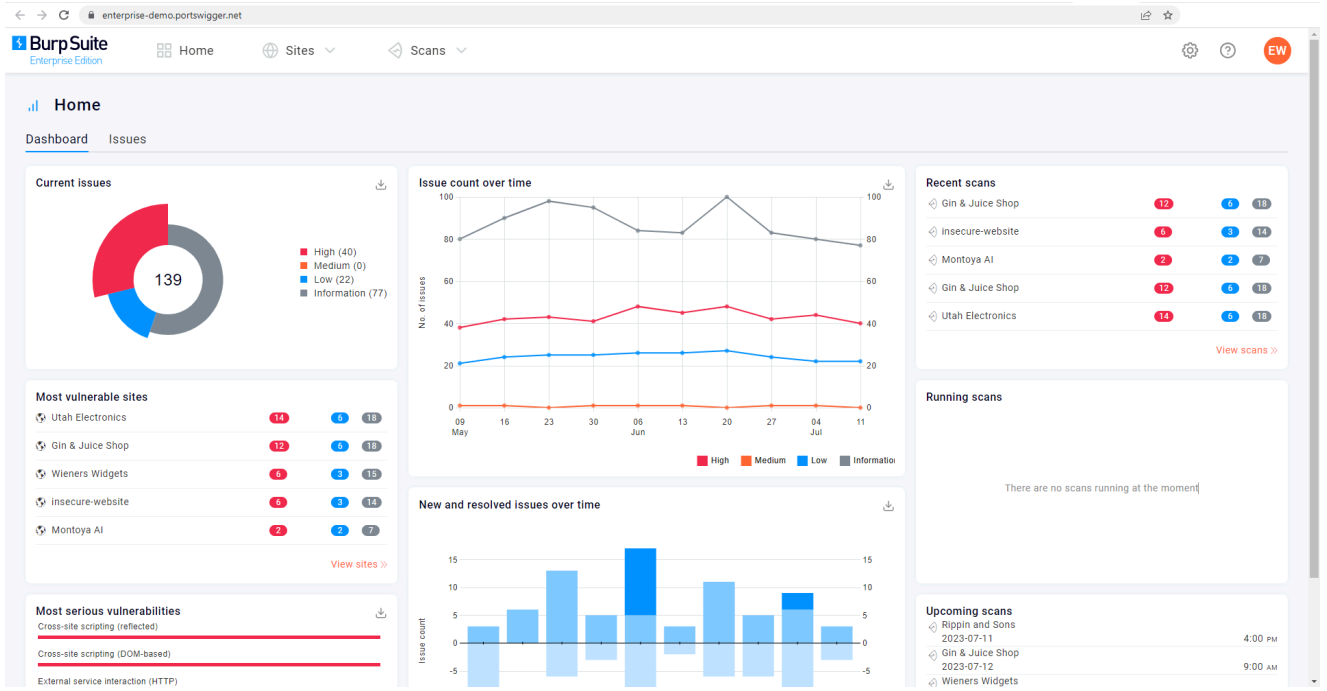
- **Otomatik Zafiyet Tarayıcı (Vulnerability Scanner):** Manuel eforu azaltmak için hedef yapıdaki zafiyetleri otonom olarak test eden gelişmiş bir tarama motoru.
- **Hız Kısıtlamasız Fuzzer / Brute-Forcer: (Fuzzing:** Bir sisteme beklenmeyen, rastgele veri setleri -payloads- göndererek uygulamanın çökmesini veya mantıksal hata vermesini sağlama tekniği). Community sürümünde ağa gönderilen istek hızı kısıtlanmıştır (rate-limited). Professional sürümde ise donanımın elverdiği maksimum eşzamanlı bağlantı (concurrent connection) ile kaba kuvvet saldırıları gerçekleştirilebilir.
- **Proje Kaydı ve Raporlama:** Uzun süren sızma testi oturumlarını (session) duraklatıp kaydetme ve elde edilen bulguları kurumsal standartlarda raporlama yeteneği.
- **Dahili API Entegrasyonu:** CI/CD süreçlerine veya diğer özel güvenlik araçlarına (custom tooling) entegre edilebilmesi için dışarıya açık bir API sunar.
- **Limitsiz Extension (Eklenti) Erişimi:** BApp Store üzerinden indirilebilen veya özel yazılmış eklentilerin kullanımında hiçbir kısıtlama yoktur.
- **Burp Suite Collaborator:** Özel bir istek yakalayıcı mekanizmadır (Payload'ların tetiklenip tetiklenmediğini anlamak için dışarıya yapılan DNS/HTTP isteklerini dinler). Özellikle **Out-of-Band (OAST)** ve **Blind** (Kör - sunucunun ekrana doğrudan hata basmadığı durumlar) zafiyetlerini tespit etmek için hayati bir bileşendir. Portswigger'ın kendi sunucularında veya self-hosted (kendi barındırdığınız) olarak çalıştırılabilir.

2. Burp Suite Enterprise

Community ve Professional sürümlerinden mimari olarak tamamen farklı bir yaklaşıma sahiptir. Manuel penetrasyon testlerinden ziyade, **DevSecOps** süreçlerinde **Sürekli Tarama (Continuous Scanning)** yapmak için tasarlanmıştır.

- **Çalışma Mantığı:** Yerel makinede (tarayıcı ile entegre) çalışmak yerine, doğrudan merkezi bir sunucu (Server) üzerine kurulur.
- **Amaç:** Tıpkı ağ altyapı taramalarında Nessus'un otonom rol üstlenmesi gibi, Enterprise sürümü de hedef web uygulamalarını tanımlı periyotlarla arka planda otomatik olarak

tarar ve kurumsal güvenlik zafiyeti takibi sağlar.



Çapraz Platform (Cross-Platform) Uyumluluğu

DİKKAT: Dokümantasyon ve pratik eğitimler genellikle Windows işletim sistemi üzerindeki Burp Suite arayüzünü temel alsa da, aracın çekirdeği **Java** tabanlı olduğu için işletim sisteminden bağımsız (agnostik) çalışır. Gerek TryHackMe **AttackBox** ortamında gerekse yerel Kali Linux veya Parrot OS kurulumlarında, aracın fonksiyonelliği, menü dizilimi ve trafik manipülasyon mantığı %100 aynıdır.

Burp Suite Community Sürümü: Temel Bileşenler ve Teknik İşlevleri

Burp Suite Community sürümü, Professional lisansına kıyasla hız kısıtlamaları ve otonom tarama eksiklikleri barındırsa da, web uygulama sızma testlerinde (Web Application Penetration Testing) ihtiyaç duyulan manuel analitik araçların neredeyse tamamını eksiksiz sunar. Bu araçlar, birbirleriyle tam entegre çalışan bir ekosistem oluşturarak, tespit edilen bir zafiyetin adım adım istismar edilmesine (exploitation) olanak tanır.

Aşağıda, bu ekosistemi oluşturan temel bileşenlerin mimari yapıları ve kullanım amaçları derinlemesine incelenmiştir.

Proxy (Vekil Sunucu): Operasyonun Merkezi

Burp Suite'in en çok bilinen ve tüm veri akışının kontrol edildiği kalbidir. İstemci ile sunucu arasına bir **MITM** (Man-in-the-Middle - Ortadaki Adam) gibi konumlanarak web uygulamasıyla etkileşim sırasında giden tüm istekleri (Requests) ve dönen yanıtları (Responses) yakalar, duraklatır (Intercept) ve manipüle edilmesini sağlar.

Neden Kullanıyoruz? Tarayıcıların geliştirici araçları (DevTools) bazı kısıtlamalara sahiptir ve giden paketi anlık olarak dondurup değiştirmenize izin vermez. Proxy sayesinde, tarayıcının gönderdiği ham HTTP trafiğini doğrudan terminal seviyesinde görebilir ve sunucuya ulaşmadan önce değiştirebiliriz.

Repeater (Tekrarlayıcı): Manuel Zafiyet Analizi

Repeater, Proxy üzerinden yakalanan veya geçmişte (HTTP History) kaydedilen bir isteği alıp, üzerinde sınırsız kez değişiklik yaparak hedef sunucuya tekrar tekrar göndermemizi sağlayan modüldür. Özellikle **SQLi** (Structured Query Language Injection - Veritabanı sorgularını manipüle etme zafiyeti) veya **XSS** (Cross-Site Scripting - Zararlı JavaScript kodu çalıştırma) gibi zafiyetleri tespit ederken, "deneme-yanılma" yöntemiyle özel zararlı yükler (Payloads) hazırlamak için kullanılır.

Aşağıdaki örnekte, Repeater üzerinde manipüle edilmiş bir kimlik doğrulama atlatma (authentication bypass) denemesini görüyoruz:

```
POST /login.php HTTP/1.1
Host: vulnerable-bank.com
Content-Type: application/x-www-form-urlencoded

username=admin' OR 1=1--&password=random
```

Analiz: Normal şartlarda kullanıcı adı bekleyen `username` parametresine, Repeater kullanılarak `' OR 1=1--` şeklinde bir SQL enjeksiyon yükü (payload) yerleştirilmiştir. Bu sayede parola ne olursa olsun veritabanındaki `WHERE` sorgusu her zaman doğru (TRUE) dönecek ve sisteme admin yetkileriyle giriş yapılacaktır. Repeater, bu isteği gönderip anında dönen HTTP 200 OK yanıtını ve oturum çerezini (session cookie) sağ panelde incelememizi sağlar.

Intruder (Saldırgan): Otonom Fuzzing ve Kaba Kuvvet (Brute-Force)

Belirli bir HTTP isteğindeki (örneğin bir giriş formundaki şifre alanı veya bir API'daki ID parametresi) seçili alanlara, önceden tanımlanmış kelime listelerini (wordlists) veya rastgele karakter dizilerini (fuzzing) otomatik olarak gönderen saldırı modülüdür.

ÖNEMLİ: Community sürümünde Intruder ciddi şekilde hız sınırlandırılmasına (rate-limited) tabidir. İşlem uzadıkça istekler arası bekleme süresi artar. Bu nedenle Community sürümünde devasa şifre listeleriyle brute-force yapmak yerine, daha küçük listelerle **Fuzzing** (Sistemin nasıl tepki vereceğini veya çökeceğini görmek için uç durum verileri gönderme) yapmak daha mantıklıdır.

Decoder (Kod Çözücü / Şifreleyici): Veri Transformasyonu

Siber güvenlik testlerinde veriler genellikle düz metin (plaintext) olarak iletilmez. Güvenlik duvarlarını (WAF - Web Application Firewall) atlatmak veya uygulamanın filtreleme mekanizmalarını kandırmak için zararlı yüklerin dönüştürülmesi gerekir. Decoder modülü, yakalanan verilerin kodunu çözmek (Decoding) veya hazırlanan payload'ları hedefe göndermeden önce kodlamak (Encoding) için kullanılır.

```
Ham Payload: <script>alert(document.cookie)</script>
URL Encoded: %3Cscript%3Ealert%28document.cookie%29%3C%2Fscript%3E
Base64 Encoded: PHNjcmlwdD5hbGVydChkb2N1bWVudC5jb29raWUpPC9zY3JpcHQ+
```

Analiz: Bir XSS saldırısında doğrudan `<script>` etiketini gönderirsek, sunucunun WAF bileşeni bunu tespit edip bağlantımızı kesebilir (HTTP 403 Forbidden). Ancak Decoder kullanarak bu payload'u **URL Encoding** veya uygulamanın kabul ettiği **Base64** formatına çevirirsek, filtreleri aşma ihtimalimiz artar.

Comparer (Karşılaştırıcı): Veri Farklılıkları Analizi

İki farklı veri bloğunu kelime (word) veya bayt (byte) düzeyinde yan yana karşılaştıran modüldür. Yazılım geliştirmedeki `diff` aracına benzer çalışır.

Mantıksal Kullanım Senaryosu: Eğer bir **Blind SQLi** (Kör SQL Enjeksiyonu - Sunucunun ekrana veritabanı hatası basmadığı, sadece dönen sayfanın içeriğinin değiştiği zafiyet türü) testi yapıyorsak, başarılı bir "TRUE" sorgusu ile başarısız bir "FALSE" sorgusu arasındaki sayfa boyutu (Content-Length) veya içerik farkını gözle bulmak imkansız olabilir. Her iki yanıtı (response) tek bir kısayol ile Comparer'a göndererek, iki sayfa arasındaki bir kelimelik farkı (Örn: "Hoş geldiniz" vs "Kullanıcı bulunamadı") saniyeler içinde tespit edebiliriz.

Sequencer (Sıralayıcı): Rastgelelik (Entropy) Analizi

Bir web uygulamasında güvenliğin temel taşlarından biri, tahmin edilemezliktir. Sequencer, **Session Cookie** (Oturum Çerezi), CSRF token'ları (Cross-Site Request Forgery saldırılarını önleyen jetonlar) veya parola sıfırlama bağlantıları gibi rastgele üretilmesi gereken verilerin şifreleme kalitesini test eder.

Uygulamadan binlerce token toplar ve karakter dağılımını matematiksel/istatistiksel testlere (FIPS, vb.) tabi tutar. Eğer algoritmanın rastgeleliği zayıfsa (düşük entropi), bir saldırgan gelecekte üretilecek oturum çerezlerini tahmin edebilir ve diğer kullanıcıların hesaplarını (Session Hijacking) ele geçirebilir.

Genişletilebilirlik: Extender ve BApp Store

Burp Suite'in esnekliği, kendi sınırlarının ötesine geçebilmesinden kaynaklanır. Java tabanlı çekirdek kodu, geliştiricilerin framework'e yeni özellikler eklemesine olanak tanır. Bu eklentiler yerel olarak Java ile, veya sırasıyla Jython ve JRuby yorumlayıcıları (interpreters) kullanılarak **Python** ve **Ruby** dilleriyle yazılabilir.

- **Extender (Geniřletici) Modülü:** Özel yazılmış eklentilerin araca hızlı ve kolay bir şekilde yüklenmesini ve yönetilmesini sağlayan arayüzdür.
- **BApp Store:** Üçüncü taraf (third-party) eklentilerin bulunduğu resmi pazar yeridir. Bazı gelişmiş eklentiler Professional lisansı (özellikle otomatik tarayıcı API'sini kullananlar) gerektirse de, Community sürümü için hayati öneme sahip birçok açık kaynaklı eklenti mevcuttur.

DİKKAT: Sektörde en çok kullanılan Community eklentilerinden biri **Logger++** modülüdür. Burp Suite'in yerleşik loglama yeteneğini devralır ve sadece Proxy'den geçen trafiği değil; Intruder, Repeater, Sequencer gibi tüm Burp araçlarından çıkan/giren **tüm** trafiği tek bir ekranda, gelişmiş filtreleme seçenekleriyle loglar. Bu, özellikle karmaşık API testlerinde hangi aracın hangi isteği attığını geriye dönük izlemek için kritik bir "kara kutu" görevi görür.

Burp Suite Kurulumu ve Çapraz Platform (Cross-Platform) Ortam Yapılandırması

Burp Suite; web veya mobil uygulama güvenlik değerlendirmeleri (assessments), **Pentesting** (Sızma testleri), **Bug Bounty Hunting** (Ödül avcılığı) ve hatta güvenli yazılım geliştirme döngüsünde (SDLC) ağ trafiği düzeyinde hata ayıklama (debugging) süreçleri için endüstri standardı bir demirbaştır. Operasyonel ortama göre kurulum prosedürleri, işletim sisteminin dosya hiyerarşisine ve yetki modeline (authorization model) göre değişiklik gösterir.

DİKKAT: Eğer TryHackMe ekosistemindeki **AttackBox** ortamını kullanıyorsanız, Burp Suite sisteme önceden entegre edilmiş, gerekli bağımlılıkları çözülmüş ve yapılandırılmış olarak gelir; herhangi bir kurulum eforu gerektirmez.

Dağıtım ve Paket Yöneticisi Entegrasyonu (Kali Linux)

Offensive security (saldırgan güvenlik) odaklı, sektörel bir dağıtım olan **Kali Linux** ortamında Burp Suite, varsayılan araç setiyle birlikte kurulu (pre-installed) gelir. Ancak sistemin minimal (lightweight) bir kurulumu yapılmışsa veya paket manuel olarak kaldırılmışsa, dağıtımın resmi `apt` (Advanced Package Tool - Debian tabanlı sistemlerde yazılım paketlerini yöneten araç) depoları üzerinden sisteme yeniden entegre edilebilir.

```
sudo apt update && sudo apt install burpsuite -y
```

Analiz: Bu komut zincirinde öncelikle sistemin yerel paket indeksleri güncellenir (`update`), ardından `burpsuite` paketi en üst düzey sistem yöneticisi yetkileriyle (`sudo`) doğrudan resmi depolardan çekilerek sisteme global olarak kurulur. Global kurulum, aracın işletim sistemindeki herhangi bir terminal dizininden doğrudan çağrılabilmesini sağlar.

Manuel Kurulum Süreçleri (Windows, macOS ve Diğer Linux Dağıtımları)

Kali Linux dışındaki işletim sistemleri için geliştirici firma PortSwigger, **Burp Suite Community Edition**'in derlenmiş (compiled) ve o platforma özel kurulum sihirbazlarını (installers) resmi web sitesi üzerinden sunar.

Windows ortamında süreç standart bir çalıştırılabilir dosya (executable - .exe) üzerinden arayüzle ilerlerken; Linux ortamlarında (Ubuntu, Parrot, Arch vb.) terminal üzerinden bir bash script (betik) yürütülmesi (execution) gerekir. Sızma testi uzmanı olarak, Linux kurulumlarında işletim sisteminin yetki mantığını anlamak şarttır.

Linux Ortamında Kurulum Mantığı: Sudo vs. Non-Sudo Farkı

Linux sistemlerde PortSwigger'dan indirdiğiniz kurulum betiğini çalıştırırken kullanacağınız yetki (privilege) seviyesi, Burp Suite'in dosya sisteminde fiziksel olarak nereye yerleşeceğini ve sistemin **PATH** (İşletim sisteminin çalıştırılabilir komutları aradığı varsayılan global izin yolları listesi) değişkenine eklenip eklenmeyeceğini doğrudan belirler.

```
# Root yetkisi olmadan (Standart kullanıcı yetkisiyle) kurulumu tetikleme komutu:  
bash burpsuite_community_linux_v202X_X_X.sh
```

Analiz: Eğer kurulum betiğini yukarıdaki gibi `sudo` yetkisi olmadan (non-sudo) çalıştırırsanız, güvenlik sınırları (sandboxing) gereği betik kök dizinlere (örneğin `/opt/` veya `/usr/local/bin/`) yazma işlemi yapamaz. Bu durumda yazılım, işlemi başlatan kullanıcının izole ev dizinine (home directory) kurulmak zorundadır.

ÖNEMLİ: `sudo` olmadan yapılan kurulumlarda sistem, Burp Suite'i varsayılan ortam değişkenlerine (Environment Variables) dahil etmez. Araç **PATH** değişkenine eklenmediği için, terminale sadece `burpsuite` yazıp Enter'a basarsanız "command not found" (komut bulunamadı) hatası alırsınız. Bu durumda programı tetiklemek için, kurulumun yapıldığı tam dosya yoluna (Absolute Path) giderek çalıştırılabilir dosyayı doğrudan işaret etmeniz gerekir:

```
~/BurpSuiteCommunity/BurpSuiteCommunity
```

Analiz: Yukarıdaki dosya yolu, yetkisiz bir kullanıcı kurulumunda ana başlatıcı (launcher) dosyanın bulunduğu spesifik konumdur. `~/` sembolü, Linux dosya sisteminde o an oturum açmış kullanıcının ev dizinini (`/home/kullanici_adi/`) temsil eder.

Sistem yöneticisi (`sudo`) yetkisiyle yapılan bir kurulum ise tam tersine, aracı global bir dizine yerleştirir, **PATH**'e otomatik olarak ekler ve tüm kullanıcı profillerinden erişilebilir kılar. Kurulum aşamalarında varsayılan (default) ayarları kabul etmek genel olarak güvenlidir; ancak kurulumun dosya sisteminde nereye müdahale ettiğini bilmek, ileride eklenti (extension) geliştirirken veya Java bellek hatalarını (Heap Space errors) çözerken konfigürasyon dosyalarını manuel düzenlemek için kritik bir gereksinimdir.

Burp Suite Başlatma Süreçleri ve Dashboard (Kontrol Paneli) Analizi

Burp Suite'in ilk başlatılma aşaması ve **Dashboard** (Kontrol Paneli) arayüzü, sızma testi oturumunun temel kurallarının belirlendiği yerdir. Bu aşamadaki konfigürasyon tercihleri, testin kalıcılığını ve aracın otonom davranışlarını doğrudan etkiler.

Proje Yapılandırması ve Bellek Yönetimi (Memory Management)

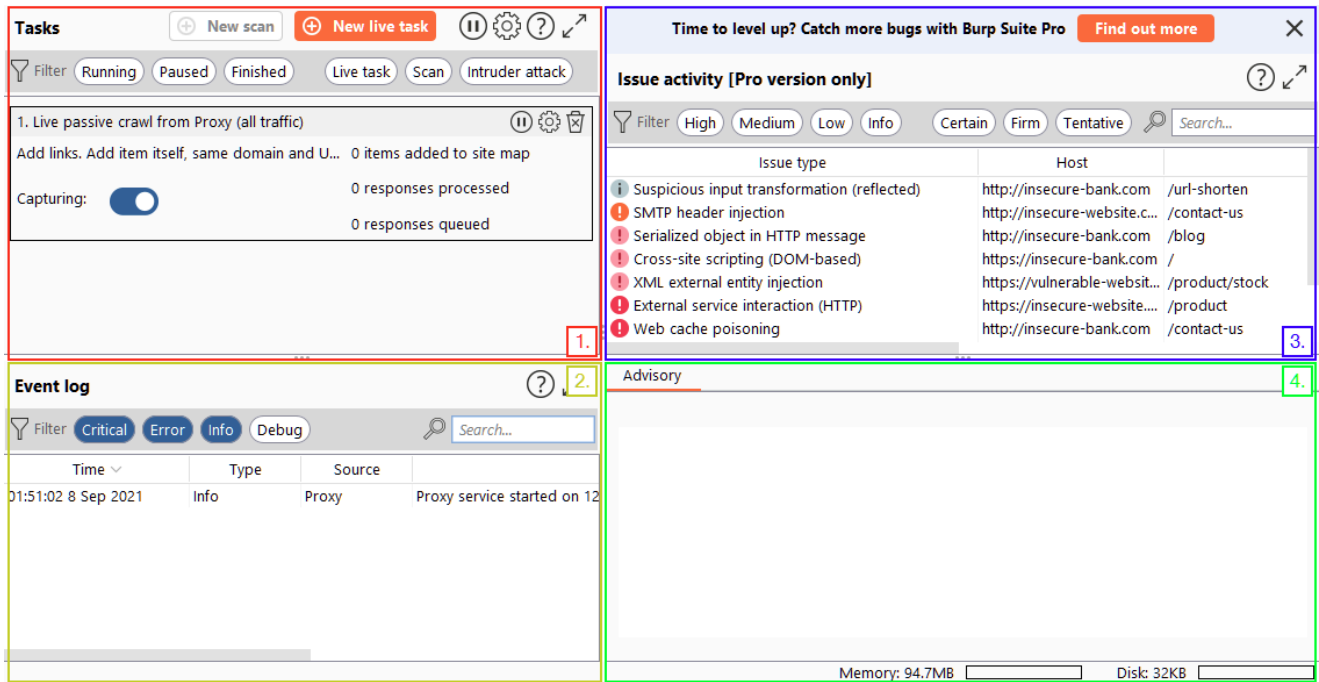
Aracı başlattığınızda ve lisans sözleşmesini (EULA) kabul ettiğinizde, sistem sizden bir proje türü (Project Type) seçmenizi ister. Bu adım, aracın yakaladığı HTTP/HTTPS trafiğini, yapılandırmaları ve bulguları dosya sisteminde nasıl saklayacağını belirler.

ÖNEMLİ: Burp Suite Community sürümünde bu aşamada "Temporary Project" (Geçici Proje) seçeneği dışında bir alternatife izin verilmez ve sadece "Next" diyerek ilerlemek zorundasınız. Bunun teknik anlamı şudur: Araç, tüm oturum verilerini (session data) bilgisayarın uçucu belleğinde (RAM) veya işletim sisteminin geçici dizinlerinde tutar. Eğer Burp Suite beklenmedik şekilde çökerse veya siz aracı kapatırsanız, saatler süren manuel analizleriniz, yakaladığınız istekler ve oluşturduğunuz payload'lar kalıcı olarak silinir. Professional sürümünde ise `.burp` uzantılı proje dosyaları oluşturularak tüm veriler diske fiziksel olarak yazılır ve operasyon daha sonra kaldığı yerden devam edebilir.

Bir sonraki adımda gelen konfigürasyon ekranında, genellikle varsayılan ayarların (Default Settings) kullanılması önerilir. Varsayılan ayarlar, aracın **Proxy** dinleyicisini (listener) ağ üzerinde izole ve güvenli olan **127.0.0.1 (localhost)** adresi ve **8080. portu** üzerinde başlatacak şekilde önceden yapılandırılmıştır. "Start Burp" butonuna basıldığında ana arayüz yüklenir.

Dashboard (Kontrol Paneli) Mimarisi

Ana ekran (Dashboard), Burp Suite'in komuta merkezidir. İlk bakışta karmaşık görünse de, mantıksal olarak dört ana çeyreğe (quadrant) bölünmüş asimetrik bir yapıya sahiptir. Test sırasında sistemin arka planda ne yaptığını buradan izleriz.



1. Tasks (Arka Plan Görevleri)

Sol üst köşede yer alan bu bölüm, Burp Suite'in siz uygulamayı test ederken arka planda otonom olarak yürüteceği görevleri tanımladığınız yerdir.

Community sürümünde varsayılan olarak **Live Passive Crawl** (Canlı Pasif Tarama - proxy üzerinden geçen trafiği sadece izleyerek uygulamanın izin ağacını ve yapısını çıkarma işlemi) görevi aktiftir.

Teknik Arka Plan: "Pasif" denmesinin sebebi, aracın hedef sunucuya ekstra, manipülatif veya zararlı hiçbir paket göndermemesidir. Siz tarayıcıda gezinirken (proxy üzerinden), o sadece giden/gelen yanıtları okur ve arka planda **Site Map** (Site Haritası) oluşturur. Professional sürümünde ise bu alana "Live Active Scan" (Canlı Aktif Tarama) eklenebilir; bu durumda araç, yakaladığı her parametreye anında SQLi veya XSS payload'ları enjekte etmeye başlar.

2. Event Log (Olay Günlüğü)

Sol alt köşede yer alan bu panel, Burp Suite'in sistemle ve ağla olan etkileşiminin terminal benzeri dökümünü verir. Sızma testi sırasında bir şeyler ters gittiğinde (Örn: trafiği yakalayamama) bakılacak ilk hata ayıklama (debugging) noktası burasıdır.

```
14:05:10 - Proxy service started on 127.0.0.1:8080
14:05:12 - Live Passive Crawl task started
14:10:33 - Proxy: Failed to start listener on 127.0.0.1:8080. Address
already in use.
```

Analiz: Yukarıdaki örnek Event Log çıktısında, en sondaki satır kritik bir hatayı gösterir. Sistemin **8080** numaralı portu halihazırda başka bir uygulama (örneğin arka planda çalışan bir Tomcat sunucusu veya başka bir proxy aracı) tarafından işgal edilmektedir. Bu durumda

"B planı" olarak, Proxy ayarlarından dinleyici portunu **8081** gibi boş bir porta çekmemiz ve tarayıcı ayarlarını buna göre güncellememiz gerekir.

3. Issue Activity (Bulgu Aktivitesi)

Sağ üst köşede yer alan bu bölüm, ağırlıklı olarak Burp Suite Professional'ın otomatik tarama (automated scanner) motoru tarafından beslenir. Bulunan zafiyetler (vulnerabilities) anlık olarak burada listelenir.

Bu listedeki bulgular iki ana kritere göre derecelendirilir:

- **Severity (Kritiklik Seviyesi):** High (Yüksek), Medium (Orta), Low (Düşük) ve Information (Bilgi). Bir sistemde Remote Code Execution (Uzaktan Kod Çalıştırma) High iken, sunucu versiyonunun gözükmesi Information seviyesindedir.
- **Confidence (Eminlik/Doğruluk Derecesi):** Certain (Kesin), Firm (Güçlü), Tentative (Şüpheli). Zafiyetin türüne göre araç bazen tam emin olamaz (özellikle Blind zafiyetlerde) ve analistin manuel doğrulamasını ister.

4. Advisory (Güvenlik Tavsiyeleri ve Raporlama)

Sağ alt köşede yer alan ve Issue Activity sekmesiyle entegre çalışan detay panelidir. Yukarıdan bir zafiyet seçildiğinde, bu alt panelde zafiyetin teknik tanımı, nasıl oluştuğu, uygulamanın verdiği hatalı yanıtın (response) kanıtı ve en önemlisi **Remediation** (İyileştirme/Kapatma) önerileri sunulur. Community sürümünde aktif tarama özelliği kapalı olduğu için, bu son iki çeyrek genellikle boş kalır veya sadece çok basit pasif bulguları (Örn: şifrelenmemiş form iletimleri) gösterir.

Bağlamsal Yardım Entegrasyonu (Contextual Help)

Arayüzün çeşitli panellerinde, sekmelerinde ve ayar menülerinde bulunan ? (soru işareti) ikonları yüzeysel bir yardım menüsü değildir.

DİKKAT: Bu ikonlar "Bağlama Duyarlı" (Context-Aware) olarak çalışır. Hangi alt modüldeyseniz (Örn: Intruder'ın Payload Processing sekmesi), soru işaretine tıkladığınızda PortSwigger'ın devasa resmi dokümantasyonunda tam olarak o spesifik ayarın ne işe yaradığını ve nasıl kullanıldığını anlatan teknik belgeye yönlendirilirsiniz. Ezberin tıkanıp nokta, framework'ün her bir dışlisinin çalışma mantığını öğrenmek için sahadaki en büyük yardımcınız bu ikonlardır.

Burp Suite Arayüz Navigasyonu ve İleri Düzey İş Akışı Yönetimi

Burp Suite üzerinde gerçekleştirilen güvenlik değerlendirmeleri (assessments) sırasında hız ve verimlilik, hedef sistemdeki anlık değişimleri yakalayabilmek için kritik öneme sahiptir. Aracın arayüz (GUI) tasarımı, rastgele menülerden ziyade sızma testi yaşam döngüsünün (pentesting lifecycle) farklı aşamalarını yansıtacak şekilde hiyerarşik olarak yapılandırılmıştır.

Ana navigasyon mantığı, üst kısımda yer alan yatay menü çubukları üzerinden modüller arası geçişlere ve bu modüllerin kendi içlerindeki spesifik alt işlevlerine dayanır.

Makro ve Mikro Navigasyon: Modüller ve Alt Sekmeler (Sub-Tabs)

Burp Suite, devasa bir framework olduğu için işlevleri ana modüllere bölmüştür. Ekranın en üst sırasındaki ana menü çubuğu (**Module Selection**), sızma testi sırasındaki makro düzeydeki duraklarınızı temsil eder (Örn: **Proxy**, **Intruder**, **Repeater**).

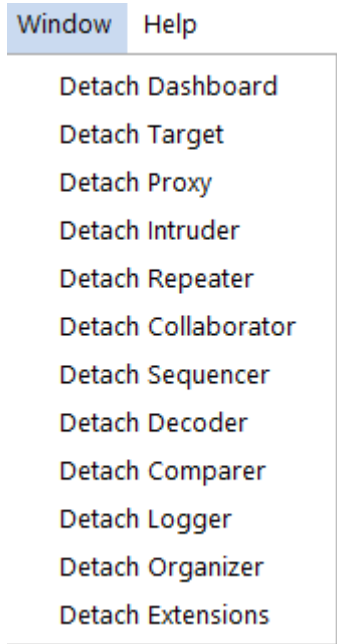


Bir modüle tıkladığınızda, hemen altında ikinci bir yatay menü çubuğu belirir. Bu **Sub-Tabs** (Alt Sekmeler), seçili modülün mikro düzeydeki konfigürasyonlarını veya farklı görünümünü barındırır.

Mantıksal Örnek: **Proxy** modülüne tıkladığınızda, alt menüde **Intercept** (Araya girilen paketlerin canlı olarak duraklatıldığı ekran), **HTTP history** (Geçmişte akıp giden tüm trafiğin loglandığı ekran) ve **Proxy settings** (Dinleyici portu veya SSL sertifika ayarlarının yapıldığı ekran) gibi alt sekmeler görürsünüz. Bu hiyerarşi, bir modülün hem operasyonel ekranını hem de yapılandırma ekranını aynı pencerede izole bir şekilde yönetmenizi sağlar.

Arayüz Optimizasyonu: Sekmeleri Ayırma (Detaching Tabs)

Standart tek pencereli görünüm, karmaşık ve çok adımlı saldırı senaryolarında (örneğin bir sayfada işlem yaparken arka planda API'nin nasıl tepki verdiğini izlemek gerektiğinde) yetersiz kalabilir.



ÖNEMLİ: Burp Suite, sekmeleri ana pencereden koparıp bağımsız (detached) pencerelere ayırmanıza olanak tanır. En üstteki genel uygulama menüsünden **Window** sekmesine gidip "Detach" seçeneği kullanıldığında, o an aktif olan modül ayrı bir işletim sistemi penceresine dönüşür.

Saha Pratiği: Profesyonel sızma testi uzmanları genellikle çoklu monitör (multi-monitor) kurulumları kullanır. **Repeater** modülünü bir ekrana ayırıp (detach) manuel payload denerken, diğer ekranda ana Burp Suite penceresinde **Proxy > HTTP history** sekmesini açık bırakırlar. Böylece hedefe gönderdikleri zararlı yükün, arka planda farklı bir endpoint (uç nokta) üzerinde beklenmedik bir dış çağrıya (out-of-band interaction) veya hataya sebep olup olmadığını gerçek zamanlı olarak izleyebilirler.

Hızlı Navigasyon: Profesyonel İş Akışı İçin Klavye Kısayolları

Zamanın ve odaklanmanın hayati olduğu anlarda (örneğin kısa süreli bir oturum çerezi - session cookie - ölmenden önce payload'u hazırlayıp göndermek gerektiğinde) fare ile menüler arasında gezinmek büyük bir zaman kaybıdır. Sisteme tam hakimiyet kurmak için varsayılan klavye kısayollarının (shortcuts) kas hafızasına işlenmesi gerekir.

Aşağıdaki kısayollar, test sırasındaki en yoğun trafik geçişlerini sağlar:

Shortcut	Tab
Ctrl + Shift + D	Dashboard (Kontrol Paneli - Arka plan görevleri ve event log için)
Ctrl + Shift + T	Target Tab (Hedef Sekmesi - Site haritası ve kapsam/scope ayarları için)
Ctrl + Shift + P	Proxy Tab (Vekil Sunucu - Trafik manipülasyonu için)
Ctrl + Shift + I	Intruder Tab (Saldırgan - Fuzzing ve Brute-force operasyonları için)
Ctrl + Shift + R	Repeater Tab (Tekrarlayıcı - Manuel payload denemeleri için)

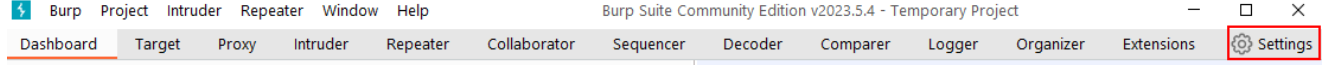
Analiz: Yukarıdaki kısayol bloklarında Ctrl + Shift kombinasyonu, Burp Suite'in çekirdek navigasyon tetikleyicisidir. Örneğin; **Proxy** üzerinden yakaladığınız bir isteği Ctrl + R ile **Repeater**'a gönderdikten (send to Repeater) hemen sonra, Ctrl + Shift + R kısayolunu kullanarak anında Repeater sekmesine geçiş yapabilir ve manipülasyon işlemine saniyeler içinde başlayabilirsiniz. Bu akıcılık, sektördeki kıdemli analistlerin en temel alışkanlıklarından biridir.

Burp Suite Konfigürasyon Mimarisi ve Ayar Yönetimi

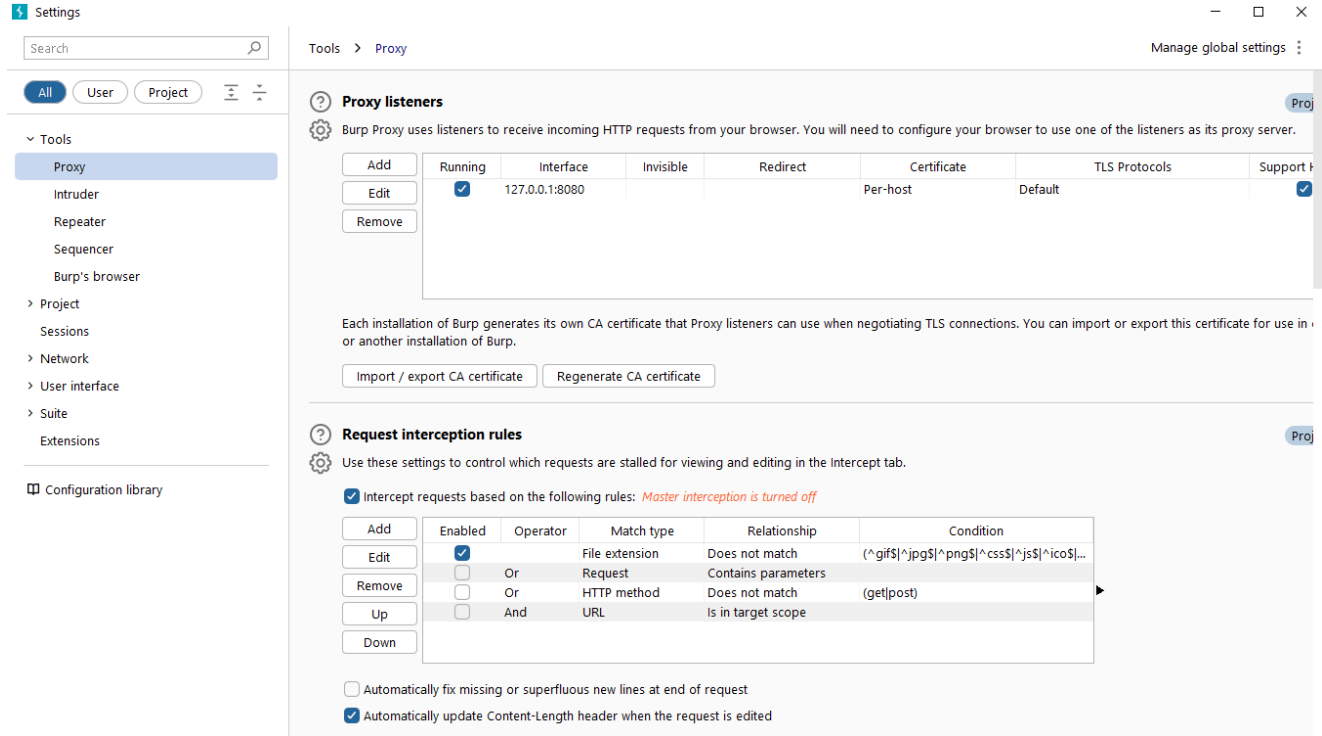
Burp Suite üzerinde gerçekleştirilen güvenlik değerlendirmelerinde, aracın ağ trafiğini nasıl işleyeceğini ve hedefe nasıl tepki vereceğini belirleyen yapılandırmalar temel olarak iki ana mimariye ayrılır. Bu mimarilerin arkasındaki mantığı kavramak, test ortamının stabilitesi ve operasyonel verimlilik için esastır.

Global (User) ve Proje (Project) Ayarları Mantığı

Sistemin üst navigasyon çubuğundan erişilen **Settings** (Ayarlar) menüsü, yapılandırmaları etki alanlarına ve kalıcılıklarına göre ikiye ayırır. Global ayarlar (User settings) tüm Burp Suite kurulumunu ve sistemdeki gelecekteki oturumları kapsayan temel kuralları (baseline configuration) belirlerken, proje ayarları (Project settings) sadece o anki aktif test oturumuna özel, izole konfigürasyonları içerir.

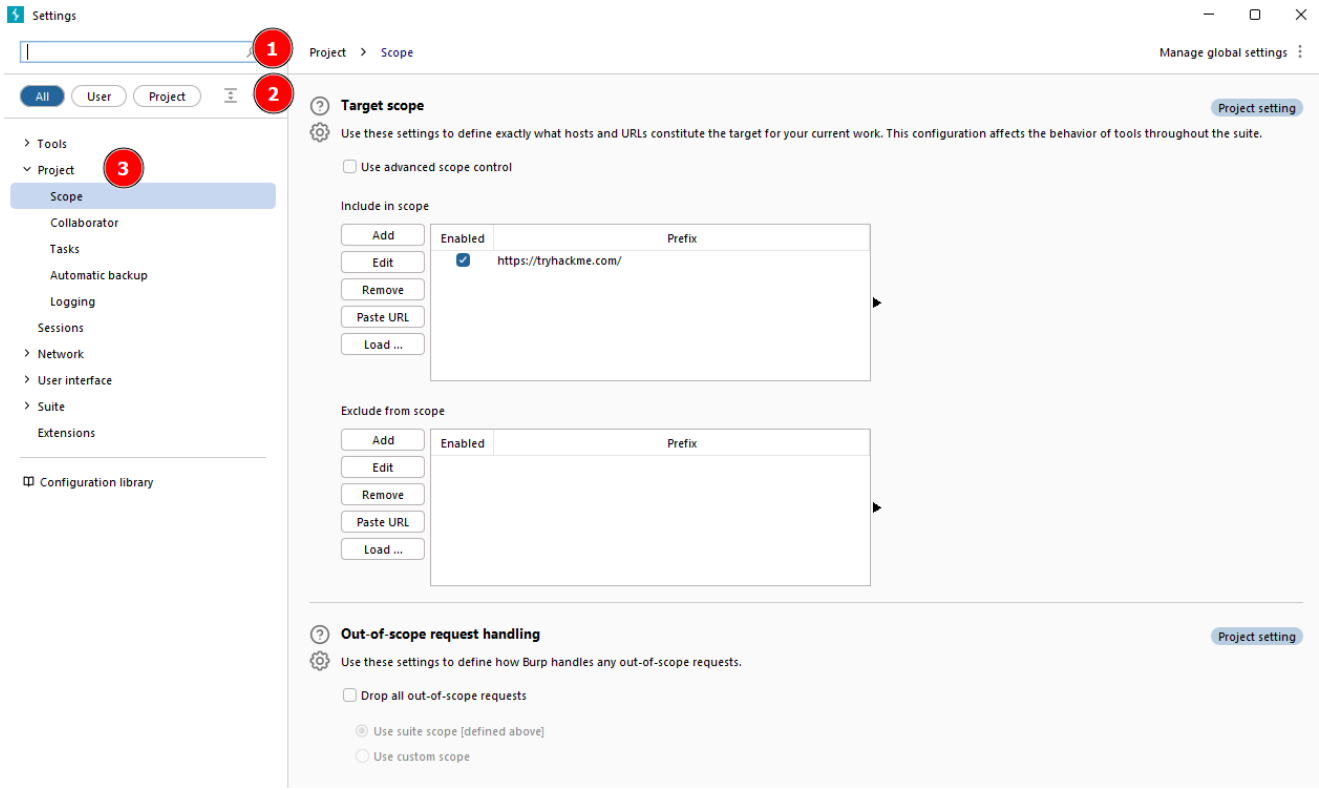


ÖNEMLİ: Community sürümünde proje kaydetme yeteneği teknik olarak kısıtlandığı için, oturum sonlandığında bellek üzerindeki tüm proje bazlı ayarlar kalıcı olarak yok olur. Operasyon sırasında bu ayrımın farkında olmak, özelleştirilmiş test konfigürasyonlarının kaybını önlemek adına alınan kritik bir karardır.

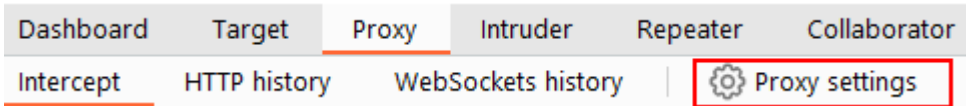


Arayüz Filtreleme ve Modüler Erişim Hiyerarşisi

Ayarlar penceresinin sol menüsünde yer alan **1.Search** (Arama) ve **2.Type filter** (Tip filtresi) özellikleri, framework içerisindeki spesifik bir yapılandırmaya anında ulaşmayı sağlar.



Analiz: Bu hiyerarşik yapılandırma paneli, karmaşık sızma testi senaryolarında hedeflenen modülün (örneğin Proxy) ayarlarına doğrudan, izole bir erişim imkanı tanır. Eğer test sırasında bir modül (örneğin Proxy) beklenen şekilde çalışmazsa, sistemin yapılandırmalarını "User" veya "Project" seviyesinde filtreleyerek sorunun kaynağına hızla müdahale edebilir ve sistemi stabil durumuna geri döndürebiliriz. Birçok modül arayüzü, bu spesifik kategorilere doğrudan atlamamızı sağlayan kısayol butonları da barındırır.



Burp Proxy Mimarisinin Temelleri ve Trafik Manipülasyonu

Burp Proxy, Burp Suite ekosisteminin mutlak merkezidir. Analistin (istemci) ile hedef web sunucusu arasında bir **MITM** (Man-in-the-Middle - Ortadaki Adam) vekil sunucusu olarak konumlanarak, ağ üzerinden akan tüm **Requests** (İstekler) ve **Responses** (Yanıtlar) üzerinde mutlak hakimiyet kurmamızı sağlar. Bu modül sayesinde trafik izlenebilir, duraklatılabilir, manipüle edilebilir, anında imha edilebilir veya daha derinlemesine analiz için diğer Burp bileşenlerine yönlendirilebilir.

Araya Girme (Intercepting) ve Trafik Üzerinde Otorite Kurma

Bir sızma testinde **Proxy** modülünün en kritik yeteneği, ağ paketlerini hedef sunucuya ulaşmadan önce havada yakalayıp bekletmesidir.

Proxy > Intercept sekmesi altında bulunan **Intercept is on** (Araya girme açık) butonu aktif olduğunda, tarayıcıdan çıkan her HTTP isteği terminal ekranımıza düşer ve biz bir aksiyon alana kadar (veya zaman aşımına uğrayana kadar) sunucuya iletilmez.



Bu aşamada analistin önünde dört temel operasyonel seçenek vardır:

1. **Forward (İlet):** Paketi olduğu gibi veya üzerinde manuel değişiklikler yaptıktan sonra hedef sunucuya gönderir.
2. **Drop (Düşür):** İsteği tamamen imha eder. Sunucu bu isteği hiç görmez, istemci tarafı (tarayıcı) ise bağlantı sıfırlandı hatası alır. (Örneğin, arka planda sürekli çalışan ve analizi kirlüten gereksiz analitik veya telemetri isteklerini engellemek için kullanılır).
3. **Action (Yönlendir):** Yakalanan isteği, otomatize veya manuel analizler için framework'ün diğer modüllerine (**Intruder**, **Repeater** vb.) gönderir.
4. **Edit (Düzenle):** Paketin ham verisine (header, body, cookie) doğrudan müdahale eder.

Aşağıdaki örnek, duraklatılmış ve manipülasyon için bekleyen bir yetki yükseltme (Privilege Escalation) isteğini temsil etmektedir:

```
POST /api/v2/updateRole HTTP/1.1
Host: api.target.com
Content-Type: application/json
Authorization: Bearer eyJhb...

{"user_id": 451, "role": "customer"}
```

Analiz: **Intercept** açıkken bu paketi yakaladığımızda, veri henüz veritabanına ulaşmamıştır. `role` parametresindeki `"customer"` değerini `"admin"` olarak değiştirip **Forward** butonuna basarak, uygulamanın yetkilendirme (authorization) zafiyeti barındırıp barındırmadığını test edebiliriz. İşlem başarısız olursa, bir sonraki deneme için paketi **Repeater** modülüne göndeririz. Trafiğin normal akışına dönmesini istersek, **Intercept is on** butonuna tıklayarak durumu **Intercept is off** (Araya girme kapalı) konumuna getiririz.

Arka Plan Loglama: HTTP ve WebSockets History

ÖNEMLİ: Sızma testi metodolojisinde her paketi tek tek araya alıp (intercept) incelemek operasyonel hızı öldürür. Burp Suite'in mimari avantajı, **Intercept is off** konumunda olsa bile, üzerinden geçen tüm trafiği varsayılan olarak yakalaması ve kalıcı olarak kaydetmesidir.

Dashboard	Target	Proxy	Intruder	Repeater	Collaborator	Sequencer	Decoder	Comparer	Logger	Organizer	Extensions	Settings
Intercept	HTTP history	WebSockets history	Proxy settings									
Filter: Hiding CSS, image and general binary content												
# ^	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title		
8	https://assets.tryhackme.com	GET	/js/popper.min.js			200	34557	script	js			
10	https://assets.tryhackme.com	GET	/js/jquery.min.js?v=3.5.1	✓		200	128920	script	js			
18	https://assets.tryhackme.com	GET	/js/bootstrap431.min.js			200	93752	script	js			
19	https://assets.tryhackme.com	GET	/js/script.js?v=3.11	✓		200	21758	script	js			
20	https://assets.tryhackme.com	GET	/js/validation.js			200	1935	script	js			
40	https://tryhackme.com	GET	/assets/pace/pace.js			200	28469	script	js			
42	https://cdnjs.cloudflare.com	GET	/ajax/libs/cookieconsent2/3.0.3/cookie...			200	20784	script	js			
43	https://kenwheeler.github.io	GET	/slick/slick/slick.js			200	84960	script	js			
44	https://tryhackme.com	GET	/cdn-cgi/scripts/5c5dd728/cloudflare-...			200	1624	script	js			
45	https://assets.tryhackme.com	GET	/js/paths.js?v=1.3	✓		200	8891	script	js			

- **HTTP history:** Tarayıcı üzerinden hedef uygulamada normal bir kullanıcı gibi gezinirken (Passive Crawling - Pasif Tarama), arkada dönen tüm API çağrıları, resim yüklemeleri ve form gönderimleri bu sekmede loglanır. Analist daha sonra bu logları filtreleyerek geriye dönük (retrospective) analiz yapar ve saldırı yüzeyini (Attack Surface) belirler.
- **WebSockets history:** Modern web uygulamaları (canlı sohbetler, anlık borsa ekranları, oyunlar) HTTP yerine, sunucu ile istemci arasında çift yönlü, sürekli açık bir kanal sağlayan **WebSocket** protokolünü kullanır. Burp Proxy, bu durumu da yerel olarak destekler ve WebSocket mesajlaşmalarını (TCP socketleri üzerinden akan ham verileri) ayrı bir sekmede loglayarak, bu modern mimarilerdeki zafiyetleri (örneğin Cross-Site WebSocket Hijacking - CSWSH) tespit etmemize olanak tanır.

Proxy Settings: İleri Düzey Trafik Kuralları

Proxy settings butonu, vekil sunucunun otonom davranışlarını ve filtreleme mekanizmalarını yapılandırdığımız kontrol merkezidir. Aracı sadece bir "paket dinleyici" olmaktan çıkarıp, "otomatik bir manipülasyon motoruna" dönüştürür.

1. Response Interception (Yanıtları Araya Alma)

Varsayılan yapılandırmada Burp Proxy, sunucudan dönen **Responses** (Yanıtlar) için araya girmez.

Teknik Neden: Her resim, CSS, veya JavaScript dosyası yanıtı için manuel onay (Forward) vermek tarayıcıyı kilitler ve test sürecini imkansız hale getirir.

Response interception rules

Use these settings to control which responses are stalled for viewing and editing in the Intercept tab.

☒ Intercept responses based on the following rules: *Master interception is turned off*

	Enabled	Operator	Match type	Relationship	Condition
Add	☒		Content type header	Matches	text
Edit	☐	Or	Request	Was modified	
Remove	☒	Or	Request	Was intercepted	
Up	☐	And	Status code	Does not match	^304\$
Down	☐	And	URL	Is in target scope	

☒ Automatically update Content-Length header when the response is edited

Ancak "Intercept responses based on the following rules" (Yanıtları aşağıdaki kurallara göre araya al) seçeneği aktif edilerek, mantıksal (Boolean) kurallar yazılabilir. Örneğin: *Sadece Content-Type başlığı "application/json" olan ve içerisinde "error" kelimesi geçen yanıtları durdur*. Bu sayede, istemci tarafındaki (Client-side) güvenlik kontrollerini atlatmak için sunucudan gelen "false" (başarısız) yanıtını, tarayıcıya ulaşmadan havada "true" (başarılı) olarak değiştirebiliriz.

2. Match and Replace (Eşleştir ve Değiştir)

Ağ trafiği üzerinde anlık, otomatik ve dinamik modifikasyonlar yapmak için kullanılan en güçlü araçtır. **Regex** (Regular Expressions - Düzenli İfadeler; metin formlarındaki spesifik desenleri tespit etme standardı) kullanarak gelen ve giden isteklerdeki spesifik alanları otomatik olarak değiştirir.

Aşağıda, bir mobil API zafiyetini tespit etmek için yazılmış tipik bir "Match and Replace" kuralının mantıksal yapısı bulunmaktadır:

Kod snippet'i

```
# Match (Eşleştirilecek kural - Regex):
^User-Agent:.*$

# Replace (Yerine yazılacak değer - Düz Metin):
User-Agent: Mozilla/5.0 (iPhone; CPU iPhone OS 16_5 like Mac OS X)
AppleWebKit/605.1.15
```

Analiz: Hedef uygulamanın masaüstü versiyonunda görünmeyen ancak mobil versiyonunda aktif olan gizli bir geliştirici API'sini aradığımızı varsayalım. Her isteğin (request) başlığındaki User-Agent kısmını manuel değiştirmek yerine, bu kuralı yazarız. Burp Proxy giden tüm isteklerdeki (.) User-Agent satırını yakalar ve otomatik olarak iOS cihaz imzasıyla değiştirir. Bu otonom yetenek, özellikle **WAF** (Web Application Firewall) atlatma senaryolarında, IP adreslerini taklit etmek (Örn: X-Forwarded-For: 127.0.0.1 eklemek) veya tüm isteklerdeki yetkisiz oturum çerezlerini anında yetkili bir çerezle değiştirmek için hayati öneme sahiptir.

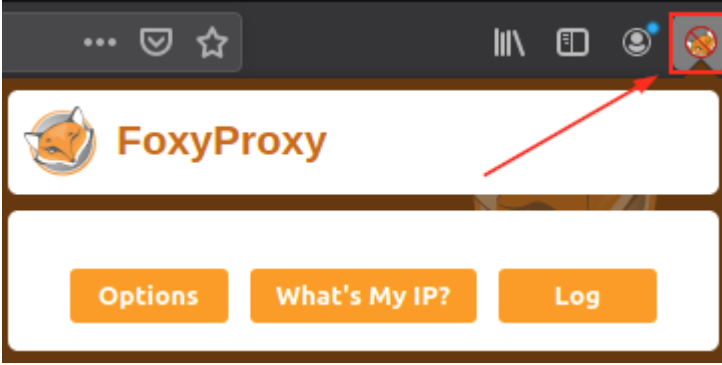
Burp Proxy ve İstemci Entegrasyonu: FoxyProxy Yapılandırması ve İlk Yakalama (Intercept) Operasyonu

Sızma testi operasyonlarında Burp Suite'in trafiği manipüle edebilmesi için, istemcinin (tarayıcının) ağ isteklerini doğrudan varsayılan ağ geçidine (default gateway) veya DNS sunucusuna göndermek yerine, yerel makinedeki Burp dinleyicisine (listener) yönlendirmesi gerekir. İşletim sisteminin global proxy ayarlarını değiştirmek, tüm sistem trafiğini (işletim sistemi güncellemeleri, arka plan servisleri, telemetriler) Burp'e sokarak logları kirleteceği ve sistemi yavaşlatacağı için tercih edilmez. Bunun yerine sektörel standart olarak izole bir ortam sağlayan **Firefox** tarayıcısı ve **FoxyProxy** eklentisi (extension) kullanılır.

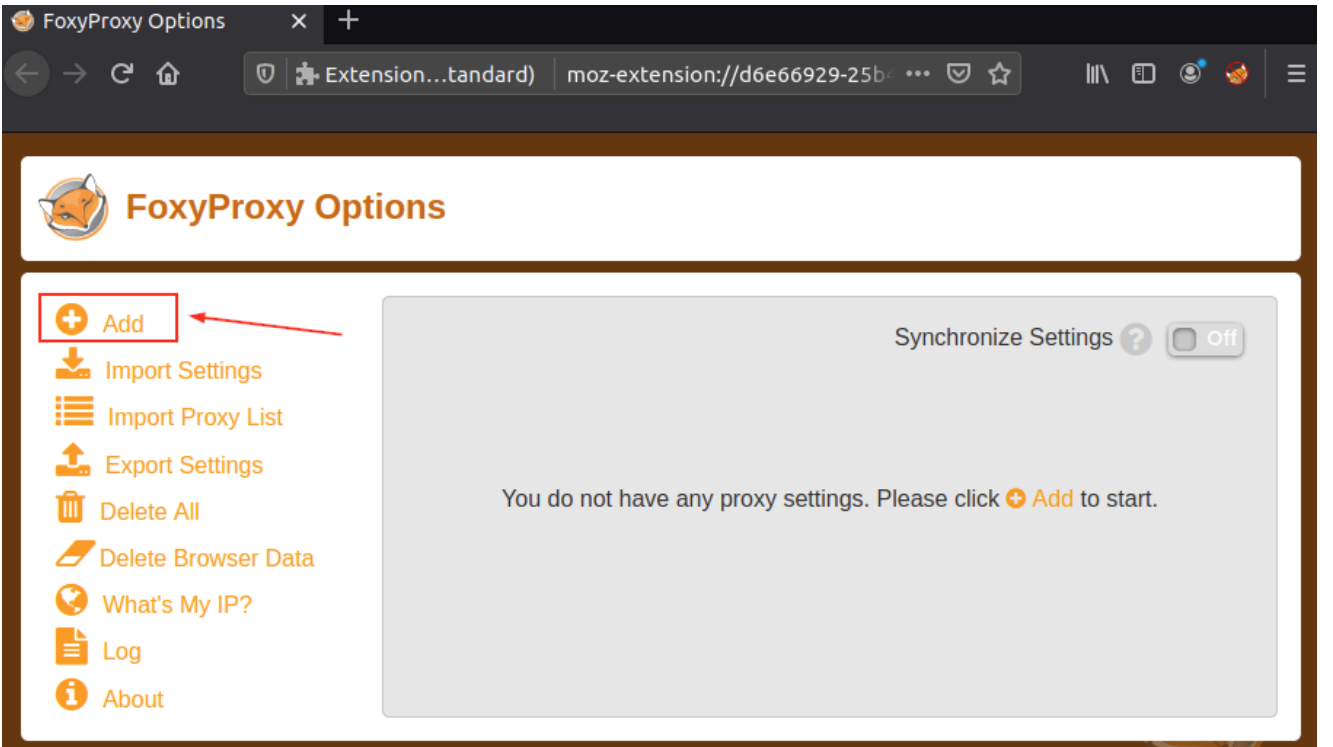
FoxyProxy, tarayıcının ağ çıkış kurallarını işletim sisteminden bağımsız olarak, tek bir tıklamayla anlık değiştirmemizi sağlayan bir uzantıdır.

FoxyProxy Yapılandırma Parametreleri ve Ağ Mantığı

Eklenti [FoxyProxy Basic extension](#) kurulduktan sonra, tarayıcının sağ üst köşesindeki FoxyProxy ikonuna tıklanarak "Options" (Seçenekler) menüsüne girilir.



"Add" (Ekle) butonu ile yeni bir vekil sunucu kuralı oluşturulur.



Bu kural setine aşağıdaki spesifik ağ değerleri girilmelidir:

Title: Burp Suite (Operasyonel Tanımlayıcı)
Proxy IP: 127.0.0.1
Port: 8080

 **Add Proxy**

Title or Description (optional)

Burp

Color

#66cc66

Proxy Type

HTTP

Proxy IP address or DNS name ★

127.0.0.1

Port ★

8080

Username (optional)

username

Password (optional) 👁

Cancel

Save & Add Another

Save

Analiz: Neden bu değerleri giriyoruz? **127.0.0.1** (Loopback adresi / Localhost), trafiğin fiziksel ağ arayüzü kartına (NIC - Network Interface Card) çıkmadan doğrudan makine içinde, işletim sisteminin kendi iç yönlendirmesinde kalmasını sağlar. **8080** ise Burp Suite'in ilk başlatıldığında HTTP/HTTPS trafiğini yakalamak için varsayılan olarak açtığı (listening) TCP bağlantı noktasıdır. Kural kaydedilip (Save) FoxyProxy üzerinden seçilerek aktif edildiğinde, Firefox'tan çıkan tüm web trafiği doğrudan bu yerel sokete (socket) çarparak Burp Suite'in içine düşecektir.

Yakalama (Intercept) İşlemi ve İstemci Davranış Analizi

FoxyProxy üzerinden trafik Burp'e yönlendirildikten sonra, Burp Suite arayüzünde **Proxy** sekmesine geçilir ve **Intercept is on** (Araya girme aktif) butonunun devrede olduğundan emin olunur. Ardından Firefox üzerinden hedef makineye (örneğin `http://**MACHINE_IP**/`) bir istek atılır.

Dashboard

Target

Proxy

Intruder

Repeater

Collaborator

Sequencer

Intercept

HTTP history

WebSockets history

Proxy settings

Forward

Drop

Intercept is on

Action

Open browser

ÖNEMLİ: Bu isteği gönderdiğiniz an tarayıcının sekmesinde yükleme ikonunun (spinner) sürekli döndüğünü ve sayfanın yanıt vermediğini (hanging) göreceksiniz. Bu bir hata değil, operasyonun başarıyla çalıştığının ve hedefe giden paketi havada yakaladığının kesin kanıtıdır.

Teknik Arka Plan: Arka planda gerçekleşen olay şudur: Tarayıcı hedefe gitmek için bir HTTP GET isteği oluşturmuş ve bunu ****127.0.0.1:8080**** adresindeki Burp Suite'e iletmıştır. Burp Suite paketi tuttuğu için istek henüz hedef sunucuya (****MACHINE_IP****) ulaşmamıştır. Tarayıcı, TCP/IP protokolü gereği hedef sunucudan gelecek bir HTTP 200 OK veya benzeri bir yanıtı beklediği için bağlantıyı açık tutar ve sayfa donmuş gibi görünür.

Eğer Burp Suite üzerindeki **Intercept is on** butonunu yanlışlıkla veya unutkanlıkla açık bırakırsanız, Firefox hiçbir web sitesine erişemeyecek ve tüm sekmeleriniz "loading" (yükleniyor) durumunda sonsuza kadar bekleyecektir.

Araya Girilen Paketin Yönetimi (Context Menu)

Paket Burp Proxy üzerinde düştüğünde, terminal ekranındaki ham HTTP metnine sağ tıklayarak (Right-click) bağlamsal menüyü (Context Menu) açabilirsiniz. Bu menü sızma testinin kontrol panosudur. Buradan paketi manipüle ettikten sonra doğrudan hedefe bırakabilir (Forward), isteği tamamen imha edip tarayıcıya "bağlantı koptu" mesajı döndürebilir (Drop) veya bu spesifik isteği daha agresif, tekrarlı denemeler yapmak üzere **Repeater** veya **Intruder** gibi modüllere gönderebilirsiniz.

Operasyonel Güvenlik ve Gürültü Azaltma (Noise Reduction)

DİKKAT: Trafik yakalama (Intercept) operasyonuna başlamadan önce, tarayıcınızdaki hedef makine (Target VM) haricindeki tüm diğer sekmeleri kesinlikle kapatın.

Modern web uygulamaları arka planda sürekli olarak telemetri verileri gönderir veya açık sekmelerdeki uygulamalar **WebSocket** (İstemci ve sunucu arasında çift yönlü, sürekli açık iletişim sağlayan protokol) üzerinden "ping/pong" (kalp atışı - heartbeat) mesajları yollar. Bu durum, asıl hedefinize ait meşru istekleri bulmanızı zorlaştırarak Burp Suite geçmişinizi (HTTP History) gereksiz trafik gürültüsüyle (noise) boğar. İzole bir test ortamı (sadece hedefe odaklanmış tek bir sekme) her zaman daha temiz ve analiz edilebilir loglar üretir.

Target Sekmesi: Site Map Mimarisi ve Zafiyet Analiz Referansları

Burp Suite üzerindeki **Target** (Hedef) modülü, sızma testi (Penetration Testing) metodolojisinin bilgi toplama ve haritalama (Reconnaissance & Mapping) evresinin komuta merkezidir. Sadece trafiği filtrelemekle kalmaz; arka planda çalışan pasif izleme yetenekleri sayesinde hedef web uygulamasının tüm topolojisini, izin ağacını ve gizli uç noktalarını (endpoints) hiyerarşik bir düzende görselleştirir.

Bu modül, operasyonel kontrolü sağlamak ve analiz derinliğini artırmak için üç ana alt sekmeye (sub-tab) ayrılmıştır.

Site Map (Site Haritası): Uygulama Ağacını Çıkarmak

Sistemdeki **Proxy** aktifken tarayıcı üzerinden hedef uygulamada gezinmeye başladığınızda, Burp Suite arka planda **Site map** ağacını otomatik olarak inşa eder. Bu işleme **Passive Crawling** (Pasif Tarama - hedefe ekstra istek göndermeden sadece geçen trafiği izleyerek dizin yapısını çıkarma) denir.

Neden Hayati Öneme Sahiptir? Modern web uygulamaları ve özellikle **API** (Application Programming Interface) mimarileri her zaman görünür linkler barındırmaz. Tarayıcıda bir butona tıkladığınızda, arka planda JavaScript tarafından tetiklenen gizli bir `/api/v1/user/delete` gibi bir uç nokta çağrılabilir. **Site map**, tarayıcının geliştirici araçlarında (DevTools) gözden kaçabilecek bu asenkron istekleri yakalar ve klasör/dosya mantığında listeler.

Professional sürümü bu haritayı otonom bir örümcek (spidering/crawling) mantığıyla kendi kendine çıkarabilirken; Community sürümünde bu işlem, ilk **Enumeration** (Bilgi Toplama - bir sistemdeki geçerli kullanıcıları, dizinleri ve servisleri listeleme) adımlarında manuel gezinme ile veritabanını doldurmak için kusursuz bir veri havuzu görevi görür.

Scope Settings (Kapsam Ayarları): Operasyonel Odak ve Yasal Sınırlar

Sızma testlerinde "gürültüyü (noise) azaltmak" ve yasal sınırların (Rules of Engagement) dışına çıkmamak en kritik kurallardan biridir. **Scope settings**, hedeflenecek spesifik domain (alan adı) veya IP adreslerini dahil etmemizi (Include) veya hariç tutmamızı (Exclude) sağlar.

ÖNEMLİ: Test sırasında hedef uygulamanın Google Analytics, harici reklam sunucuları veya üçüncü parti CDN (Content Delivery Network) adreslerine giden isteklerini yakalamak, hem **HTTP history** sekmesini çöplüğe çevirir hem de yanlışlıkla kapsam dışı (out-of-scope) bir sisteme zafiyet taraması yapmanıza (yasal ihlal) neden olabilir. Kapsamı kesin bir **Regex** (Düzenli İfade) veya tam eşleşme ile belirlemek, framework'ün sadece hedefinizle ilgilenmesini garanti altına alır.

Issue Definitions (Zafiyet Tanımları): Nihai Referans Kütüphanesi

Burp Suite Community sürümü, Professional sürümündeki gibi hedefi otomatik tarayıp zafiyet bulan **Scanner** motoruna sahip değildir. Ancak, PortSwigger'ın devasa güvenlik açıkları veritabanı **Issue definitions** sekmesi altında tamamen erişilebilir durumdadır.

Bu sekme, endüstri standardı web zafiyetlerinin (SQLi, XSS, CSRF, SSRF vb.) teknik açıklamalarını, nasıl tetiklendiğini ve en önemlisi geliştiriciler için **Remediation** (İyileştirme/Yama) önerilerini barındıran yerleşik bir ansiklopedidir. Manuel testler sırasında bir bulgu elde ettiğinizde, müşteriye veya işverene sunacağınız Sızma Testi Raporu'nu

(Pentest Report) yazarken bu sekmedeki profesyonel tanımlamaları ve referans linklerini (CVSS skorları, CWE kodları) doğrudan kullanabilirsiniz.

Analiz Operasyonu: Anormal Endpoint Tespiti

Modül kapsamındaki pratik görevde, `http://**MACHINE_IP**/` adresi üzerinde manuel bir **Enumeration** işlemi gerçekleştirilmesi istenmektedir.

1. FoxyProxy üzerinden trafiği Burp Suite'e yönlendirin.
2. Ana sayfadaki tüm menü linklerine, butonlara ve alt sayfalara tıklayarak **Site map**'i besleyin.
3. **Target > Site map** sekmesine gidin ve `http://**MACHINE_IP**` ağacını genişletin.

Burada uygulamanın standart işleyişine uymayan, muhtemelen bir yönetici (admin) paneli, unutulmuş bir geliştirici (developer) dosyası veya gizli bir API çağrısı olan anormal bir uç nokta (endpoint) belirecektir.

Aşağıdaki çıktı, Site Map'te yakalanabilecek tipik bir gizli uç noktanın ham HTTP yanıtını temsil etmektedir:

HTTP

```
HTTP/1.1 200 OK
Date: Mon, 20 Apr 2026 18:50:52 GMT
Server: Apache/2.4.41 (Ubuntu)
Content-Type: application/json
Content-Length: 78

{
  "status": "debug_mode_active",
  "secret_token": "THT_839a2b5c90"
}
```

Analiz: Anormal uç noktayı tespit ettiğinizde, tarayıcı üzerinden o sayfaya fiziksel olarak gitmenize gerek yoktur. **Site map** ağacında o spesifik isteğin üzerine tıklayıp alt paneldeki **Response** (Yanıt) sekmesini açarak, sunucunun döndürdüğü ham veriyi (örneğin yukarıdaki gibi unutulmuş bir debug token'ını) doğrudan okuyabilir ve bir sonraki saldırı vektörünüzü (attack vector) bu bilgi üzerine inşa edebilirsiniz.

Burp Suite: The Basics - Task 10 (Site Map Challenge) Çözüm ve Analiz Notları

Operasyonel Hedef ve Teknik Mantık

Bu operasyonun temel amacı, hedef web uygulamasının görünür arayüzünün (Frontend) arkasında yatan gizli dizinleri ve uç noktaları (endpoints), sisteme agresif paketler

göndermeden, sadece **Passive Crawling** (Pasif Tarama) yöntemiyle tespit etmektir. **Target > Site map** modülü kullanılarak, "Security through obscurity" (Gizleyerek güvenlik sağlama) yanılgısına düşmüş geliştiricilerin bıraktığı hassas veriler (Flag) ağ seviyesinde ele geçirilecektir.

Adım Adım İstismar ve Haritalama Süreci

Adım 1: Ağ Yönlendirmesi ve Dinleyici (Listener) Kontrolü

Sistemin ağ trafiğini Burp Suite'e yönlendirmek için tarayıcı ile vekil sunucu arasındaki köprü kurulmalıdır.

- Firefox tarayıcısında **FoxyProxy** eklentisi açılır ve `127.0.0.1:8080` (Burp Suite'in varsayılan dinleyici adresi) kuralı aktif edilir.
- DİKKAT:** FoxyProxy aktif edildiğinde, tarayıcıdan çıkan tüm **TCP SYN** paketleri doğrudan bu yerel porta çarpar. Eğer Burp Suite arka planda çalışmıyorsa veya 8080 portunu dinlemiyorsa işletim sistemi bağlantıyı reddeder.

Adım 2: Intercept Yönetimi (Trafik Akışını Sağlama)

Site Map'in (Site Haritası) oluşabilmesi için isteklerin hedef sunucuya ulaşması ve sunucunun `HTTP 200 OK` gibi bir yanıt (Response) döndürmesi şarttır.

- Burp Suite üzerinde **Proxy > Intercept** sekmesine gidilir.
- Intercept is on** butonu tıklanarak **Intercept is off** (Araya girme kapalı) konumuna getirilir.
- Neden?* Eğer Intercept açık kalırsa, proxy paketleri havada tutar. Tarayıcı sunucudan yanıt alamadığı için kilitlenir (hanging) ve hedef sunucuya hiçbir paket gitmediği için **Site Map tamamen boş kalır**.

Adım 3: Manuel Bilgi Toplama (Active Enumeration)

Trafik akışı sağlandıktan sonra, hedef uygulamanın izin ağacını çıkarmak için manuel tetiklemeler yapılır.

- Tarayıcıdan `http://MACHINE_IP/` adresine gidilir.
- Sayfadaki tüm görünür linklere (`/about` , `/contact` , `/products`) tıklanır.
- Kritik Hamle:** `/ticket/` sayfasına gidilir ve buradaki form doldurulup gönderilir.
- Arka Plan Mantığı:* Form gönderildiğinde (POST isteği) veya bu sayfalar yüklenirken, arka planda çalışan JavaScript kodları, bizim tarayıcıda görmediğimiz gizli API veya izin çağrıları yapar. Burp Proxy, ağ seviyesinde dinleme yaptığı için bu asenkron gizli çağrıların hepsini yakalayıp günlüğe kaydeder.

Adım 4: Anomali Tespiti ve İstismar (Exploitation)

Yeterli trafik üretildikten sonra operasyonun analiz evresine geçilir.

- Burp Suite'te **Target > Site map** sekmesi açılır ve sol taraftaki dizin ağacından hedef IP adresi genişletilir.
- Meşru dizinlerin (Örn: /about) arasında, mantıksal isimlendirme standartlarına uymayan, yüksek entropiye sahip (rastgele karakterlerden oluşan) anormal bir uç nokta aranır: /5yjR2G.....
- Bu anormal uç noktanın üzerine tıklanır ve alt kısımdaki **Response** (Yanıt) sekmesi açılarak sunucunun döndürdüğü ham veri analiz edilir.

Sahada Karşılaşılan Kritik Hatalar ve Çözüm Mimarileri

Operasyon sırasında karşılaşılabilecek iki majör ağ/konfigürasyon hatası ve bunların teknik çözüm yolları aşağıdadır:

HATA 1: "The proxy server is refusing connections"

Görsel Belirti: Tarayıcıda siyah bir hata ekranı belirir ve hedefe ulaşılamaz. **Teknik Analiz (Root Cause):** FoxyProxy trafiği 127.0.0.1:8080 adresine yönlendirmektedir ancak işletim sisteminde bu portu dinleyen (Listening) aktif bir servis yoktur. İşletim sistemi bu isteğe **TCP RST** (Reset) paketi ile cevap vererek bağlantıyı reddeder. **Çözüm Algoritması:**

1. Burp Suite'in açık ve tamamen yüklenmiş olduğundan emin ol.
2. Burp Suite kapalıysa başlat. Açıkta **Proxy > Proxy settings** (veya Options) sekmesine git.
3. **Proxy listeners** tablosunda 127.0.0.1:8080 arayüzünün solundaki **Running** kutucuğunun işaretli olduğunu doğrula. İşaretli değilse manuel olarak aktifleştire.

HATA 2: Tarayıcının Sonsuz Yükleme (Hanging) Döngüsüne Girmesi ve Site Map'in Boş Kalması

Görsel Belirti: Sayfa sekmelerinde yükleme ikonu sürekli döner, sayfa asla açılmaz ve **Target > Site map** sekmesi "Site map URL view is empty" uyarısı verir. **Teknik Analiz (Root Cause):** Burp Suite üzerinde **Intercept is on** aktiftir. Tarayıcıdan çıkan paketler Burp Suite'e kadar gelmiş ancak "Forward" (İlet) edilmediği için proxy içinde hapsolmuştur. Hedef sunucuya hiçbir paket ulaşmadığı için geri yanıt dönemeyiz; bu yüzden tarayıcı yanıt beklerken kilitlenir ve Burp Suite de varlığını doğrulayamadığı dizinleri Site Map'e ekleyemez. **Çözüm Algoritması:**

1. **Proxy > Intercept** sekmesine git.
2. **Intercept is on** butonuna tıklayarak durumu **Intercept is off** yap.
3. Kuyrukta bekleyen tüm paketler anında sunucuya akacak, tarayıcının kilitlenmesi çözülecek ve Site Map saniyeler içinde hedef dizinlerle dolacaktır.

Başarılı İstismar Sonrası Log Analizi (Post-Exploitation)

Site Map üzerinden anormal dizine tıklanıp **Response** sekmesi incelendiğinde elde edilen HTTP çıktısının teknik dökümü:

HTTP

```
HTTP/1.1 200 OK
Server: nginx/1.18.0 (Ubuntu)
Date: Tue, 21 Apr 2026 11:43:18 GMT
Content-Type: text/plain
Content-Length: 37
Connection: keep-alive
Front-End-Https: on

THM{NmNLZTlInGE1M.....}
```

Sızma Testi (Pentest) Raporlama Çıkarımları:

- **Zafiyet 1 - Broken Access Control (Bozuk Erişim Kontrolü):** Dönen HTTP/1.1 200 OK kodu, bu gizli dizinin arkasında hiçbir kimlik doğrulama (Authentication) mekanizmasının olmadığını kanıtlar. Dizin ismini bilen herkes veriye erişebilir.
- **Zafiyet 2 - Information Disclosure (Bilgi İfşası):** Server: nginx/1.18.0 (Ubuntu) satırı, hedef altyapının röntgenini verir. Sürüm numaraları, potansiyel RCE (Uzaktan Kod Çalıştırma) veya diğer zafiyet exploitlerini araştırmak için kritik istihbarattır (Low-severity finding).
- **Ele Geçirilen Veri:** Body (Gövde) kısmında yer alan THM{NmNLZTlInGE1M.....} metni, statik kod analizi yapılmadan ağa bırakılmış hassas bir veridir (Flag). Bu durum gerçek dünyada genellikle API anahtarları, hardcoded şifreler veya debug token'ları şeklinde karşımıza çıkar.

Burp Suite Dahili Tarayıcı (Built-in Browser) ve Sandbox Güvenlik Mimarisi

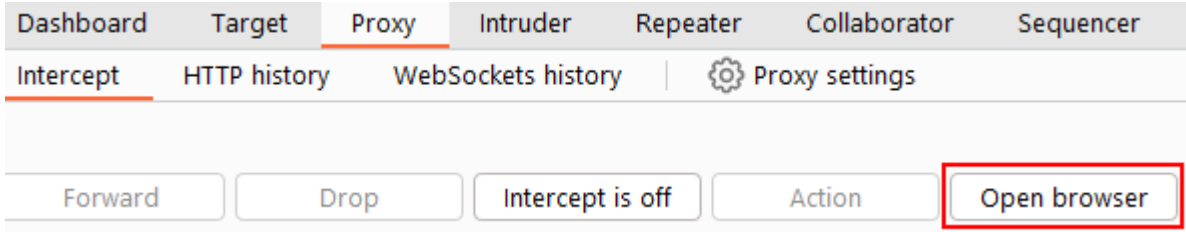
Sızma testlerinde harici bir tarayıcıyı (Firefox vb.) FoxyProxy veya işletim sistemi düzeyinde SSL/CA Sertifikası (Certificate Authority) yüklemeleriyle Burp Suite'e entegre etmek, operasyonel kurulum aşamasında zaman kaybettirebilir. Bu sürtünmeyi ortadan kaldırmak için Burp Suite, kendi içerisine önceden yapılandırılmış (pre-configured) özel bir **Chromium** tabanlı web tarayıcısı entegre etmiştir.

Operasyonel Avantaj: Sıfır Konfigürasyon ve İzolasyon

Bu dahili tarayıcı, proxy ayarları 127.0.0.1:8080 olacak şekilde sabitlenmiş ve PortSwigger'ın SSL sertifikası doğrudan tarayıcı belleğinde "güvenilir" olarak işaretlenmiş şekilde gelir.

Proxy sekmesindeki **Open Browser** (Tarayıcıyı Aç) butonuna tıklandığında açılan bu bağımsız Chromium penceresi üzerinden yapılan tüm trafik, hiçbir ek eklentiye veya işletim

sistemi müdahalesine ihtiyaç duymadan doğrudan Burp Suite'in içine düşer.



Teknik Not: Bu tarayıcının oluşturduğu arka plan gürültüsü (telemetri, güncelleme kontrolleri vb.) varsayılan olarak minimuma indirilmiştir, bu da **HTTP history** (HTTP geçmişi) sekmenizin daha temiz kalmasını sağlar.

Kritik Hata Analizi: Linux Ortamında Root Yetkisi ve Sandbox İhlali

TryHackMe **AttackBox** gibi ofansif güvenlik odaklı Linux dağıtımlarında, oturumlar genellikle en üst düzey yetki olan **root** kullanıcısı ile yönetilir. Burp Suite'i root yetkisiyle (veya `sudo` komutuyla) başlattıktan sonra **Open Browser** butonuna basarsanız tarayıcı açılmaz ve sistem arka planda aşağıdaki gibi bir çekirdek/soket hatası fırlatır:

```
[0421/152342.123456:FATAL:zygote_host_impl_linux.cc(127)] No usable sandbox!  
Update your kernel or see https://chromium... If you want to live  
dangerously and need an immediate workaround, you can try using --no-  
sandbox.
```

Analiz (Arka Plandaki Teknik Neden): Bu hatanın kaynağı **Chromium** motorunun katı güvenlik mimarisidir. Modern tarayıcılar, ziyaret edilen web sitelerindeki zararlı JavaScript kodlarının veya istismar (exploit) girişimlerinin işletim sistemine sızmasını engellemek için **Sandbox** (Korumalı Alan - izole edilmiş, sistemin geri kalanına erişimi işletim sistemi çekirdeği seviyesinde kısıtlanmış sanal çalışma ortamı) kullanır.

Chromium mimarisi, "root" yetkisiyle bir Sandbox oluşturmayı kesinlikle reddeder. Çünkü Linux mimarisinde `root`, sistemin mutlak hakimidir ve sınırlandırılmaz; bu durum Chromium'un güvenlik izolasyon mantığıyla bir paradoks yaratır ve işlem durdurulur.

Çözüm Mimarileri ve Güvenlik/Risk Değerlendirmesi

Bu mimari engeli aşmak için, operasyonun risk seviyesine göre seçilebilecek iki farklı strateji vardır:

1. Düşük Yetkili Kullanıcı (Smart / Endüstri Standardı Yol)

Gerçek dünya sızma testlerinde en uygun ve "akıllıca" olan yöntemdir. Burp Suite, sistemde oluşturulmuş sınırlı haklara sahip (low-privilege) standart bir kullanıcı hesabı üzerinden çalıştırılır.

- **Neden?** İşletim sistemi standart kullanıcıların Sandbox oluşturmalarına izin verir. Test sırasında tarayıcıda bir *0-day* (sıfırıncı gün) zafiyeti tetiklense bile, hedeften gelen bir saldırgan sadece o kısıtlı kullanıcının izole dosyalarına erişebilir; makineyi (kernel) tamamen ele geçiremez (Privilege Escalation engellenir).

2. Sandbox Korumasını Devre Dışı Bırakma (Easy / Yüksek Riskli Yol)

Eğitim ortamlarında (AttackBox), sanal laboratuvarlarda (VM) veya tek kullanımlık sistemlerde zaman kazanmak için uygulanan "kolay" yöntemdir. Chromium'un Sandbox zorunluluğunu framework üzerinden doğrudan devre dışı bırakırız.

Yapılandırma Rotası:

1. Burp Suite üst menüsünden **Settings** penceresini açın.
2. Sol taraftaki menü hiyerarşisinden **Tools -> Burp's browser** yolunu izleyin.
3. **"Allow Burp's browser to run without a sandbox"** (Burp tarayıcısının korumalı alan olmadan çalışmasına izin ver) onay kutusunu işaretleyin.

DİKKAT (Risk Analizi): Bu seçeneği aktif ettiğinizde tarayıcı çalışır, ancak **korumasız** ve **root yetkileriyle** çalışır. Eğer test ettiğiniz hedef sistem size (saldırgana) karşı bir karşı-saldırı (hack-back) düzenlerse veya incelediğiniz sayfa tarayıcıyı hedef alan zararlı bir Payload (örn: Browser Exploitation Framework - BeEF kancası) barındırıyorsa; saldırgan, sizin işletim sisteminizde doğrudan root (en üst düzey) erişimi elde eder.

TryHackMe AttackBox gibi kullan-at eğitim laboratuvarlarında makine kapatıldığında her şey sıfırlandığı için bu risk tolere edilebilir bir durumdur. Ancak profesyonel iş hayatınızda, kendi fiziksel ana makineniz (Host OS) üzerinde bu ayarı **kesinlikle** kapalı tutmalısınız.

Target Kapsamı (Scoping) ve Operasyonel Trafik İzolasyonu

Bir sızma testinde (Pentest), tarayıcı üzerinden Burp Proxy'ye yönlendirilen trafiğin tamamı hedef uygulamaya ait değildir. Modern tarayıcılar ve işletim sistemleri arka planda sürekli olarak telemetri verileri, eklenti güncellemeleri, DNS sorguları ve üçüncü taraf analiz (tracker) paketleri gönderir.

Eğer operasyonel bir **Scope** (Kapsam) belirlenmezse, Burp Suite'in **HTTP history** (Geçmiş) ve **Site map** (Site Haritası) sekmeleri dakikalar içinde devasa bir veri çöplüğüne dönüşür. Bu "gürültü" (noise), asıl hedefteki kritik zafiyetleri gözden kaçırmanıza neden olur ve en önemlisi; yasal izniniz (Rules of Engagement) olmayan sistemlere yanlışlıkla temas etmenize (out-of-scope attack) yol açabilir.

Kapsam Belirleme (Defining the Scope) Mantığı ve Uygulaması

Burp Suite'e *"Sadece şu domain veya IP adresi ile ilgilen, geri kalan tüm dünya trafiğini görmezden gel"* komutunu vermenin merkez üssü **Target** sekmesidir.

1. **Target > Site map** ekranında, sol taraftaki dizin ağacında hedefinize ait kök (root) adresi (Örn: `http://10.112.165.143`) bulun.
2. Üzerine sağ tıklayıp (Right-click) bağlamsal menüden **Add To Scope** (Kapsama Ekle) seçeneğini işaretleyin.

The screenshot displays the Burp Suite Community Edition v2023.6.2 interface. The 'Target' tab is active, showing a site map on the left with a tree structure of URLs. The main panel is divided into 'Request' and 'Response' sections. The 'Request' section shows a GET request to 'https://tryhackme.com' with various headers and a body. The 'Response' section shows the corresponding HTML response from the server, including a 200 OK status and a detailed HTML document structure. The 'Inspector' panel on the right shows the raw request and response data.

3. **Kritik Olay:** Bu işlemi yaptığınız an Burp Suite ekrana bir uyarı penceresi çıkarır: *"Kapsam dışında kalan (out-of-scope) öğelerin loglanmasını durdurmak istiyor musunuz?"* 4. Bu soruya her zaman **Yes (Evet)** yanıtı verilmelidir. **Teknik Neden:** Bu onay, Burp Suite'in bellek (RAM) ve disk yönetimini optimize eder. Araç, artık hedefin dışındaki hiçbir harici web sitesinin haritasını çıkarmak veya geçmişini kaydetmek için kaynak harcamayacaktır.

Kapsamın mantıksal kurallarını detaylı incelemek veya manuel olarak Regex (Düzenli İfade) ile yeni kurallar (Örn: `.*\target\.com` gibi tüm alt domainleri kapsama dahil etme) yazmak için **Target > Scope settings** sekmesi kullanılır. Bu ekran, trafiğin nelerin dahil edileceğini (Include) ve nelerin kesinlikle engelleneceğini (Exclude) yöneten operasyonel beyaz liste/kara liste (Allowlist/Denylist) merkezidir.

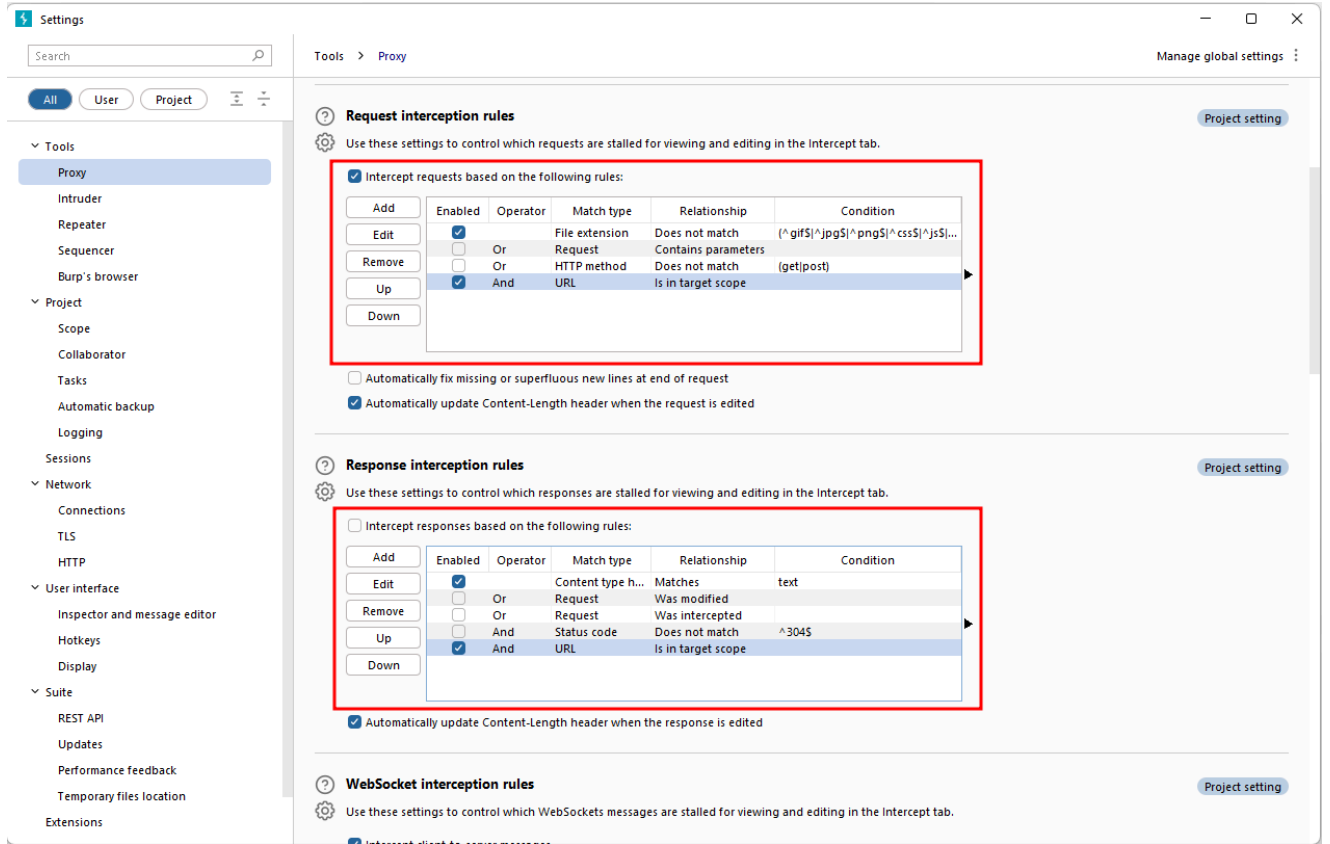
Araya Girme Tuzağı (The Intercept Trap) ve Proxy Optimizasyonu

ÖNEMLİ: Sektöre yeni giren uzmanların en sık düştüğü operasyonel hata şudur: Hedefi kapsama (Scope) eklemek ve loglamayı durdurmak, **Proxy'nin otonom araya girme (Intercept) yeteneğini durdurmaz!** Eğer sadece Scope ayarlaması yaparsanız, Burp Suite harici siteleri loglamayı bırakır ancak tarayıcınız arka planda bir Google API'sine istek

attığında, Proxy o paketi havada yakalar ve **Intercept** ekranını önünüze getirerek sizden onay (Forward/Drop) bekler. Bu durum, manuel test hızını tamamen yok eder.

Bunu önlemek ve Proxy'yi tamamen Scope'a itaat edecek şekilde izole etmek için mantıksal (Boolean) bir kural eklenmelidir:

1. **Proxy > Proxy settings** (veya eski sürümlerde Options) sekmesine gidin.
2. Ayarlar sayfasında **Intercept Client Requests** (İstemci İsteklerinde Araya Gir) tablosunu bulun. Bu tablo, Proxy'nin hangi durumlarda trafiği donduracağına karar verdiği kural setidir.
3. Tablodaki **And URL Is in target scope** (Ve URL hedef kapsamın içindeyse) kuralının solundaki onay kutusunu (checkbox) işaretleyerek aktif edin.



Mantıksal Kuralın Arka Plan İşleyişi (Boolean Logic)

EĞER (Gelen İstek Kapsam İçindeyse) = TRUE

-> Paketi Yakala ve Intercept Ekranına Düşür.

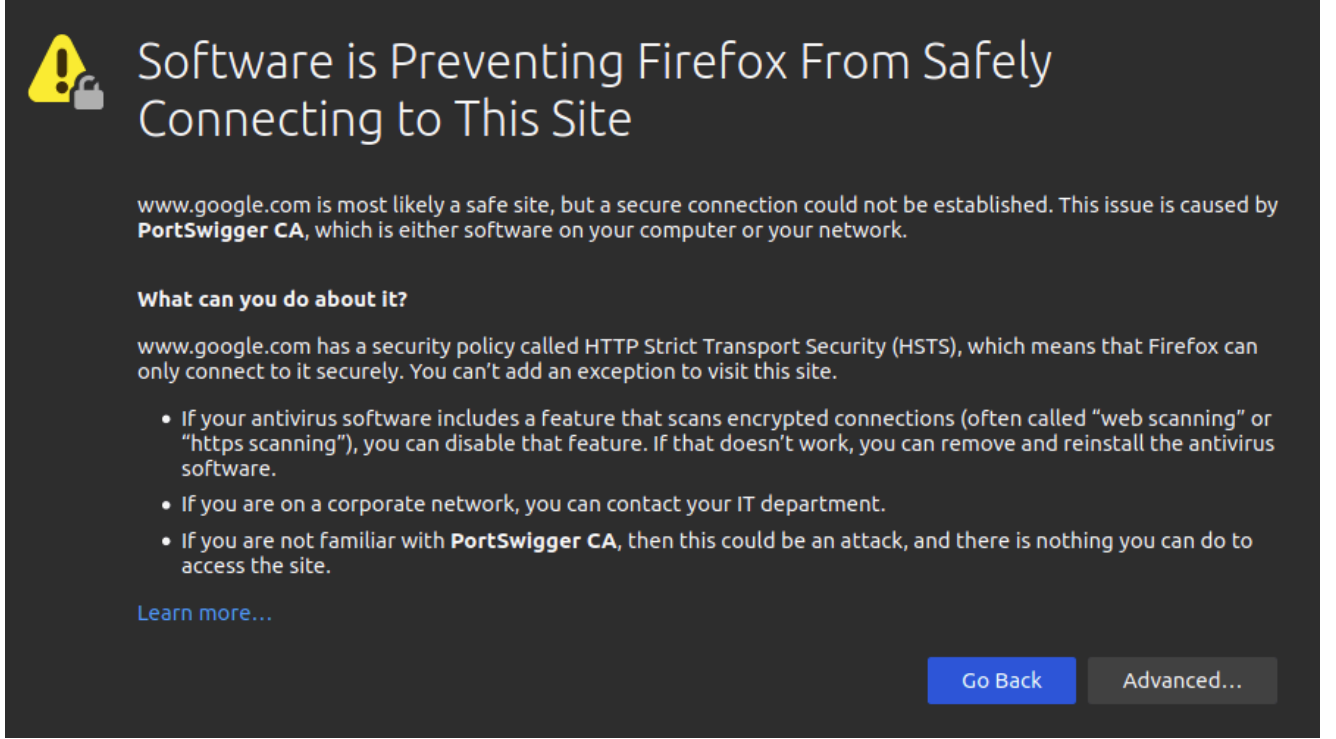
EĞER (Gelen İstek Kapsam Dışındaysa) = FALSE

-> İstekleri hiç durdurma, loglama ve doğrudan işletim sistemi üzerinden internete sal.

Analiz: Bu kural aktif edildiğinde, Proxy dinleyicisi bir filtreleme mekanizmasına dönüşür. Tarayıcınız arka planda `google-analytics.com` 'a veya başka bir adrese binlerce istek atsa bile, bu istekler Burp Suite'in radarından "sessizce ve kesintisiz" bir şekilde akıp gider. Siz sadece hedefinize (`http://10.112.165.143/`) bir istek attığınızda, sistem o paketi havada dondurarak karşınıza çıkarır. Bu, tertemiz ve yalnızca hedefe odaklanmış bir trafik görünümü (clean traffic view) elde etmenin endüstri standardı yoludur.

HTTPS Trafiğini Araya Alma (Proxying HTTPS) ve TLS/SSL MITM Mimarisi

Sızma testi operasyonlarında karşılaşılan en büyük operasyonel engellerden biri, modern web sitelerinin varsayılan olarak kullandığı **TLS** (Transport Layer Security - Veri iletiminde şifreleme sağlayan kriptografik protokol) mimarisidir. Düz metin (plaintext) akan HTTP trafiğini yakalamak sorunsuz çalışırken, `https://google.com/` gibi şifreli bir hedefe proxy üzerinden gitmeye çalıştığınızda tarayıcı bağlantıyı anında keser ve devasa bir güvenlik hatası (genellikle `SEC_ERROR_UNKNOWN_ISSUER`) fırlatır.



DİKKAT: Eğer TryHackMe ekosistemindeki **AttackBox** ortamını kullanıyorsanız, bu sertifika entegrasyonu sisteme önceden (pre-configured) yapılmıştır ve tarayıcı HTTPS trafiğini sorunsuz çözer. Ancak kendi fiziksel ana makinenizde (Host OS) profesyonel bir sızma testi altyapısı kurarken, aşağıdaki TLS kırılma mantığını ve sertifika yetkilendirme sürecini adım adım bilmek zorundasınız.

Sorunun Teknik Arka Planı: Burp Neden Hata Verdirir?

Burp Suite, istemci (tarayıcı) ile sunucu arasında bir **MITM** (Man-in-the-Middle - Ortadaki Adam) olarak çalışır. HTTPS trafiğini okuyabilmek ve manipüle edebilmek için verinin şifresini çözmesi, değiştirmesi ve tekrar şifreleyerek hedefe yollaması gerekir.

Bunu yapabilmek için Burp, hedef sunucuyla ayrı bir TLS oturumu kurarken, tarayıcıyla da ayrı bir TLS oturumu kurar. Tarayıcınız `google.com` 'a gitmek istediğinde, Burp Suite anında o domain için sahte (fake) bir sertifika üretir ve bunu tarayıcıya sunar. Ancak bu sahte sertifika, Burp'ün kendi yerleşik **CA** (Certificate Authority - Sertifika Otoritesi) olan **PortSwigger CA** tarafından imzalanmıştır. Tarayıcınızın kendi içindeki "Güvenilir Kök

Sertifikalar" (Trusted Root Store) listesinde PortSwigger bulunmadığı için, tarayıcı bu sahte sertifikayı bir siber saldırı (hijacking) girişimi olarak algılar ve bağlantıyı reddeder.

Çözüm: PortSwigger kök sertifikasını, tarayıcının güvenilir otoriteler listesine manuel olarak enjekte etmektir.

PortSwigger CA Sertifikası Entegrasyon Prosedürü (Firefox)

Sektörel standart olarak sızma testlerinde genellikle **Firefox** kullanılır çünkü Firefox, işletim sisteminin global sertifika deposunu (Windows/Linux cert store) kullanmak yerine **kendi izole sertifika deposunu** kullanır. Bu sayede sadece test tarayıcınız Burp'e güvenir, tüm bilgisayarınız değil.

Adım 1: Kök Sertifikanın (CA) Cihaza İndirilmesi

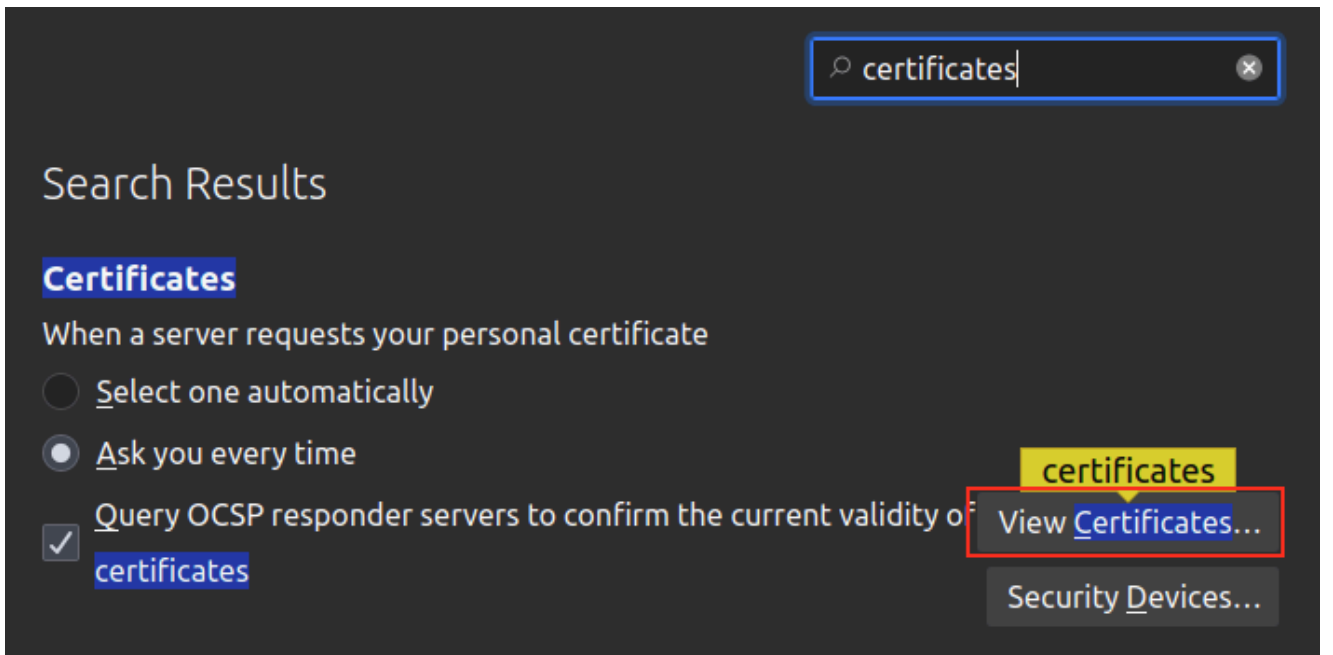
FoxyProxy üzerinden tarayıcınızın trafiği Burp Suite'e (örneğin 127.0.0.1:8080) yönlendirilmiş durumdayken, tarayıcınızın adres çubuğuna şu lokal adresi yazın:

```
http://burp/cert
```

Analiz: http://burp , internette var olan gerçek bir alan adı değildir. Trafiğiniz Burp Suite'e yönlendirildiği için, vekil sunucu bu spesifik isteği havada yakalar ve kendi içindeki web sunucusundan size `cacert.der` isimli bir dosya indirir. `.der` formatı, ikili (binary) formattaki X.509 dijital sertifikalarını temsil eder. Bu dosyayı bilgisayarınıza kaydedin.

Adım 2: Firefox Güven Merkezine (Trust Store) Erişim

Sertifikayı indirdikten sonra, Firefox'un derin yapılandırma ayarlarına girmeniz gerekir. Adres çubuğuna aşağıdaki komutu girin:



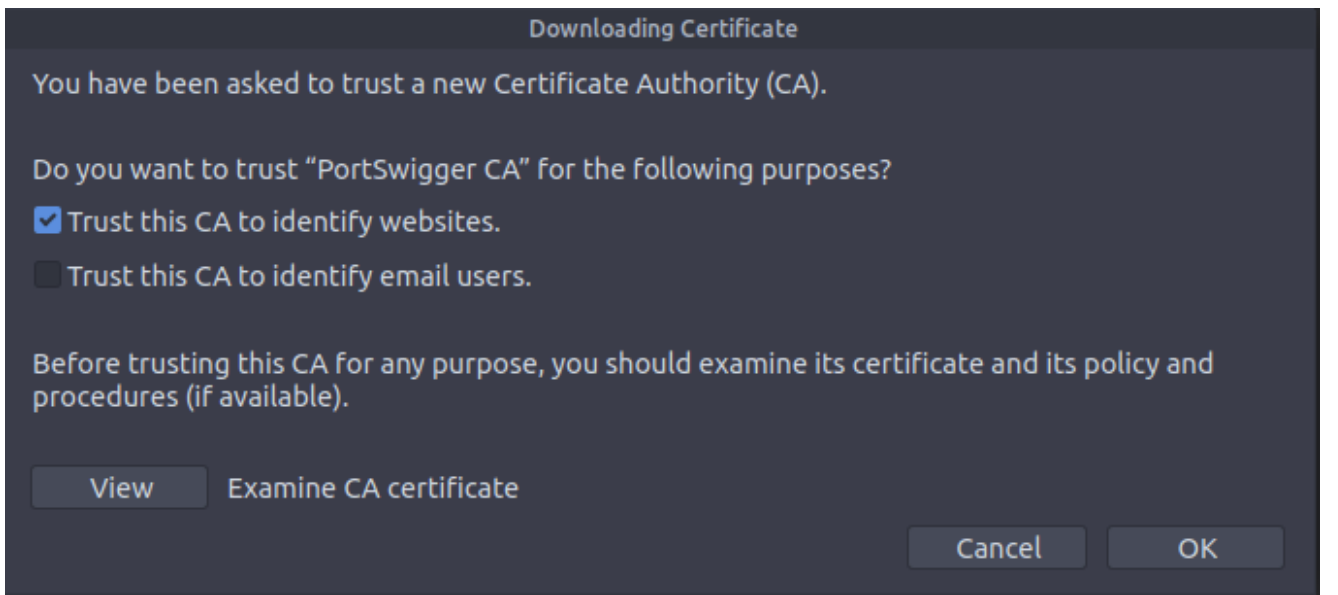
about:preferences

Açılan ayarlar sayfasının arama çubuğuna **"certificates"** (sertifikalar) yazın ve listelenen sonuçlardan **View Certificates** (Sertifikaları Görüntüle) butonuna tıklayarak Firefox Certificate Manager (Sertifika Yöneticisi) penceresini açın.

Adım 3: İçe Aktarma (Import) ve Yetkilendirme (Trust Declaration)

Sertifika yöneticisinde **Import** (İçe Aktar) butonuna tıklayın ve indirdiğiniz `cacert.der` dosyasını seçin.

KRİTİK AŞAMA: Dosyayı seçtiğinizde Firefox size bu otoriteye ne kadar güveneceğinizi soran bir onay penceresi çıkaracaktır. Ekranda yer alan şu kutucuğu mutlaka işaretleyin:

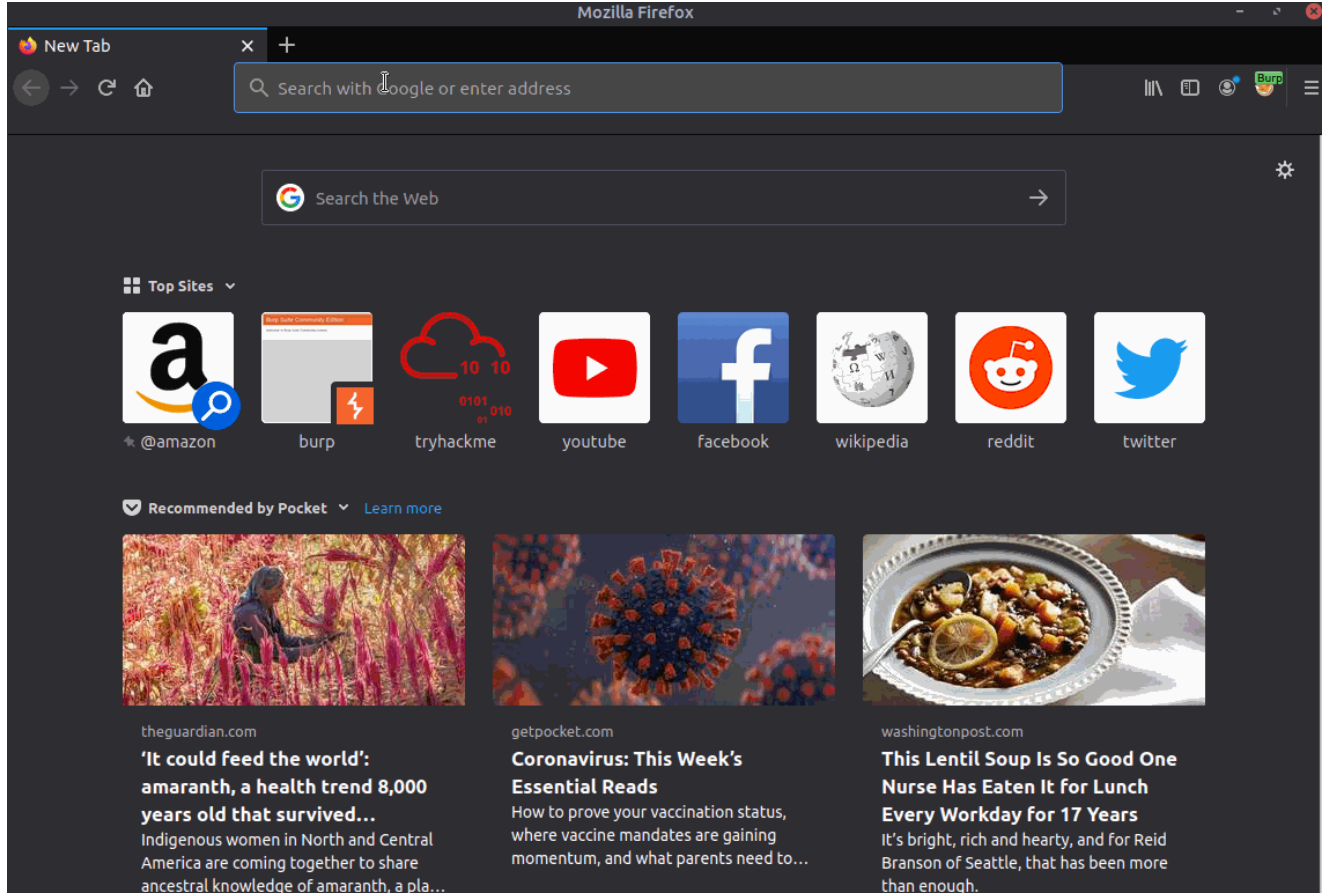


"Trust this CA to identify websites" (Web sitelerini tanımlamak için bu Sertifika Otoritesine güven)

Teknik Neden: Bu kutucuğu işaretleyerek tarayıcıya şu kesin talimatı vermiş olursunuz: *"Bundan sonra PortSwigger CA tarafından imzalanmış bir sertifika görürsen, bu sertifika kendini dünyanın en güvenli bankası veya Google olarak tanıtsa bile, onu %100 meşru ve güvenilir kabul et."* İşlemi **OK** diyerek kaydettiğinizde entegrasyon tamamlanır.

Operasyonel Sonuç: Bu işlemten sonra Proxy üzerinden `https://` ile başlayan herhangi bir hedefe gittiğinizde, tarayıcınız yeşil kilit (veya güvenli) simgesi gösterecek, şifreli trafik Burp Suite içinde düz metin (plaintext) olarak okunup manipüle edilebilir hale gelecek ve

hedefte tekrar şifrelenerek hatasız bir şekilde iletilecektir.



XSS (Cross-Site Scripting) İstismarı ve Client-Side (İstemci Taraflı) Filtre Atlama (Bypass) Operasyonu

Teorik altyapıyı ve proxy yapılandırmalarını tamamladıktan sonra, Burp Suite'in gerçek dünya senaryolarında bir saldırı vektörünü (Attack Vector) nasıl hayata geçirdiğini adım adım inceleyeceğiz. Bu operasyondaki hedefimiz `http://hedef_ip/ticket/` adresinde bulunan destek formudur.



Support

Contact Email:

Type your query here:

Submit Query!

Odaklanacağımız zafiyet türü **XSS** (Cross-Site Scripting - Çapraz Site Betik Çalıştırma) olarak adlandırılır. XSS, bir saldırganın zararlı bir istemci taraflı betiği (genellikle JavaScript) meşru bir web sayfasına enjekte ederek çalıştırmasını sağlayan kritik bir web zafiyetidir. Bu senaryoda gerçekleştireceğimiz tür **"Reflected" (Yansıyan) XSS**'tir.

Teknik Mantık: Reflected XSS kalıcı değildir (veritabanına kaydedilmez). Saldırganın gönderdiği zararlı yük (Payload), sunucu tarafından işlenir ve o anki HTTP yanıtının (Response) içine gömülerek doğrudan isteği yapan kullanıcının ekranına yansıtılır. Sunucunun girdiyi (input) HTML karakterlerine dönüştürmeden (Sanitization) ekrana basmasından kaynaklanır.

İlk Deneme ve Güvenlik Engelinin (Client-Side Filter) Analizi

Operasyona, tarayıcı üzerinden "Contact Email" (İletişim E-postası) alanına doğrudan zararlı yükümüzü girerek başlıyoruz:

```
<script>alert("Succ3ssful XSS")</script>
```

Analiz: Bu basit payload, hedef sayfanın DOM (Document Object Model) yapısına sızarak tarayıcıda ekrana bir uyarı kutusu (alert box) basmayı hedefler.

Ancak formu göndermeye çalıştığımızda tarayıcı bir hata fırlatır ve isteğin gitmesine izin vermez.

Neden Başarısız Olduk? Uygulama, **Client-Side Filter** (İstemci Taraflı Filtre) kullanmaktadır. Geliştirici, e-posta alanına özel karakterlerin (< , > , ") girilmesini engellemek için HTML5 doğrulaması (type="email") veya bir JavaScript Regex kontrolü yazmıştır.

ÖNEMLİ: İstemci taraflı kontroller **asla** bir güvenlik önlemi değildir, sadece kullanıcı deneyimini (UX) artırmak ve yanlış veri girişini önlemek içindir. Filtre kullanıcının tarayıcısında (bizim kontrolümüzde olan bir alanda) çalıştığı için, bu engeli Burp Proxy kullanarak ağ (Network) seviyesinde saniyeler içinde aşabiliriz.

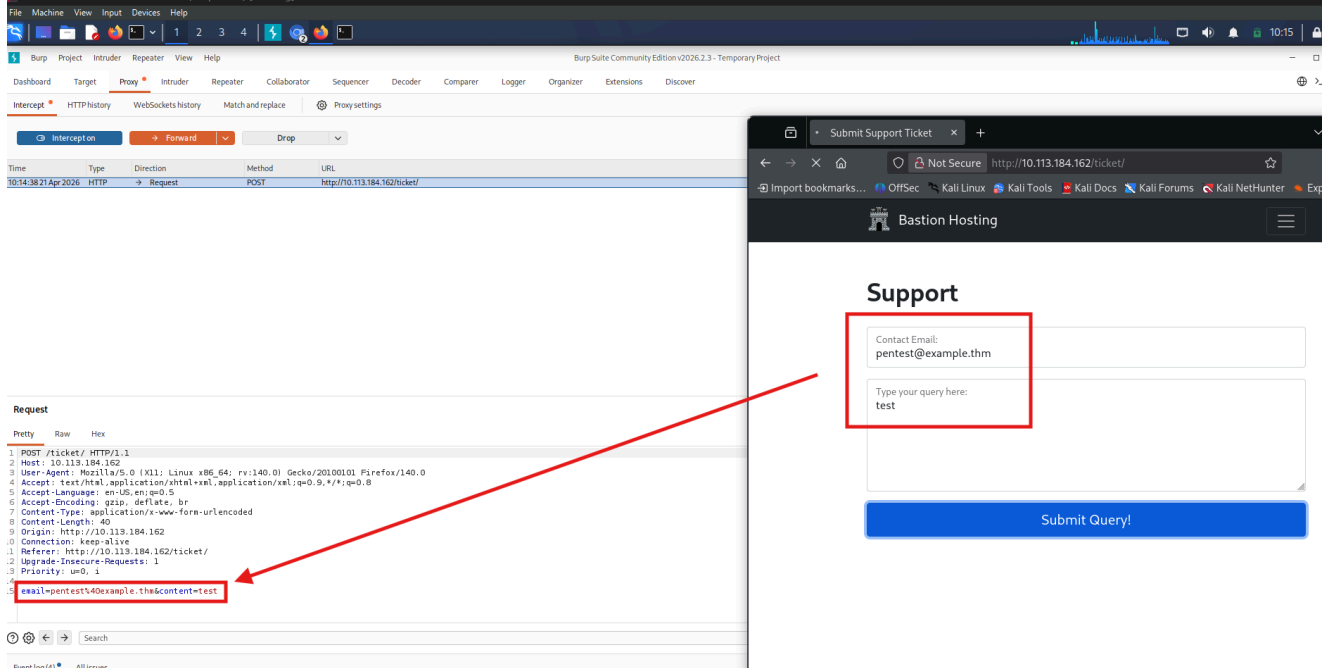
Filtre Atlatma (Bypass) ve İstismar Operasyonu

Güvenlik filtresini atlatmak için, tarayıcının kurallarına uyuyormuş gibi yapıp, veriyi sunucuya gitmeden hemen önce havada değiştireceğiz.

Adım 1: Meşru Veri Girişi ve T trafiğin Dondurulması (Intercept)

Burp Suite üzerinde **Proxy > Intercept** sekmesinde **Intercept is on** butonunun aktif olduğundan emin olun. Tarayıcıdaki destek formuna geri dönün ve uygulamanın filtrelerine takılmayacak tamamen meşru veriler girin:

- Email: pentester@example.thm
- Query: Test Attack



Submit (Gönder) butonuna bastığınızda tarayıcı, verilerin geçerli olduğunu onaylar ve HTTP POST isteğini dışarı salar. İstek, hedef sunucuya ulaşmadan önce Burp Proxy'ye düşer ve dondurulur.

Aşağıda, Burp Suite üzerinde yakalanmış olan bu meşru isteğin ham hali bulunmaktadır:

POST /ticket/ HTTP/1.1

Host: 10.113.184.162

Content-Type: application/x-www-form-urlencoded

Content-Length: 46

email=pentester@example.thm&content=Test+Attack

Analiz: İstemci taraflı filtre (tarayıcıdaki engel) artık geride kaldı. Paket ağ katmanında elimizde ve bu aşamadan sonra verinin içine ne yazarsak yazalım tarayıcı buna müdahale edemez.

Adım 2: Payload Enjeksiyonu ve Veri Transformasyonu (URL Encoding)

Yakalanan istekteki meşru e-posta adresini silip yerine XSS payload'umuzu yapııştırıyoruz:

email=<script>alert("Succ3ssful XSS")</script>&content=Test+Attack

DİKKAT: Bu isteği bu haliyle (düz metin olarak) doğrudan hedefe gönderirsek saldırımız büyük ihtimalle başarısız olacaktır. Hedef sunucu (Örn: Apache veya Nginx), HTTP paketini çözerken aradaki boşluk karakterlerini veya < > gibi HTTP protokolünde özel anlamları olan karakterleri yanlış yorumlayabilir (HTTP 400 Bad Request hatasına sebep olabilir).

Bunu önlemek ve payload'un ağ üzerinden bozulmadan (güvenli bir şekilde) iletilmesini sağlamak için, yerleştirdiğimiz payload'u fareyle seçip **Ctrl + U** klavye kısayolunu kullanarak **URL Encoding** (URL Kodlama) işlemine tabi tutuyoruz.

Hosting

Home About Contact Support

Support

Contact Email:
pentester@example.thm

Type your query here:
Test Attack

Submit Query!

```
email=%3Cscript%3Ealert%28%22Succ3ssful+XSS%22%29%3C%2Fscript%3E&content=Test+Attack
```

Teknik Arka Plan: Ctrl + U kısayolu, Burp Suite'in yerleşik **Decoder** motorunu tetikleyerek riskli karakterleri % işareti ve ardından gelen onaltılık (hexadecimal) değerlerine dönüştürür (Örn: < karakteri %3C olur). Hedef sunucu bu paketi aldığı anda, arka plandaki uygulama (PHP/Python vb.) bu karakterleri otomatik olarak tekrar normal haline (decode) çevirecek ve veritabanına/ekrana o şekilde işleyecektir.

Adım 3: İletim (Forward) ve Zafiyetin Kanıtlanması

Payload'u URL-Encoded formata getirdikten sonra, Burp arayüzündeki **Forward** (İlet) butonuna tıklayarak paketi hedef sunucuya bırakıyoruz.

- **Operasyonun Sonucu:** Sunucu, herhangi bir **Server-Side Validation** (Sunucu Taraflı Doğrulama - girdi verisini veritabanı veya kod seviyesinde filtreleme işlemi) yapmadığı için, bizim havada değiştirdiğimiz bu zararlı betiği olduğu gibi kabul eder. Sayfa yanıtı tarayıcımıza döndüğünde, HTML DOM'u içerisinde yer alan JavaScript kodumuz tetiklenir ve ekranda `Succ3ssful XSS` yazan bir Alert (uyarı) kutusu belirir. Bu, sistemin başarıyla istismar edildiğinin kesin kanıtıdır.

